

ĐẠI HỌC BÁCH KHOA HÀ NỘI

ĐỒ ÁN TỐT NGHIỆP

**Xây dựng hệ thống điểm danh thông minh
trên nền tảng Zalo Mini App**

NGUYỄN NGỌC THUẬN

thuan.nn225413@sis.hust.edu.vn

Chương trình đào tạo: Kỹ thuật máy tính

Giảng viên hướng dẫn: ThS. Lê Bá Vui

Khoa: Kỹ thuật Máy tính

Trường: Công nghệ Thông tin và Truyền thông

HÀ NỘI, 06/2026

ĐẠI HỌC BÁCH KHOA HÀ NỘI

ĐỒ ÁN TỐT NGHIỆP

**Xây dựng hệ thống điểm danh thông minh
trên nền tảng Zalo Mini App**

NGUYỄN NGỌC THUẬN

thuan.nn225413@sis.hust.edu.vn

Chương trình đào tạo: Kỹ thuật máy tính

Giảng viên hướng dẫn: ThS. Lê Bá Vui

Chữ kí GVHD

Khoa: Kỹ thuật Máy tính

Trường: Công nghệ Thông tin và Truyền thông

HÀ NỘI, 06/2026

LỜI CẢM ƠN

Trước tiên, em xin gửi lời cảm ơn chân thành và sâu sắc nhất tới thầy **ThS. Lê Bá Vui**, người đã trực tiếp hướng dẫn, định hướng và tận tình góp ý cho em trong suốt quá trình thực hiện đề án tốt nghiệp này.

Em xin gửi lời cảm ơn tới các thầy cô trong Trường Công nghệ Thông tin và Truyền thông, Đại học Bách Khoa Hà Nội, đã truyền đạt cho em những kiến thức nền tảng quý báu trong suốt những năm học vừa qua.

Cuối cùng, em xin cảm ơn gia đình và bạn bè đã luôn động viên, ủng hộ em trong quá trình học tập và thực hiện đề án.

Em xin chân thành cảm ơn!

Hà Nội, tháng 6 năm 2026

Sinh viên thực hiện

Nguyễn Ngọc Thuận

TÓM TẮT NỘI DUNG ĐỒ ÁN

Trong bối cảnh hầu hết sinh viên hiện nay đều đã sử dụng Zalo, việc triển khai ứng dụng điểm danh trực tiếp trên nền tảng Zalo Mini App mang lại sự thuận tiện lớn: người dùng có thể điểm danh ngay mà không cần cài đặt thêm bất kỳ ứng dụng mới nào. Trong khi đó, các phương pháp điểm danh truyền thống như gọi tên hay ký danh sách giấy lại tiêu tốn nhiều thời gian đối với các lớp học đông và khó bảo đảm sinh viên thực sự có mặt.

Đồ án trình bày việc xây dựng hệ thống điểm danh thông minh mang tên *Zimo Check-in* trên nền tảng Zalo Mini App. Quy trình điểm danh được thiết kế gồm bốn bước: quét mã QR động được ký bằng HMAC-SHA256 và làm mới sau mỗi 30 giây, xác minh khuôn mặt ngay trên thiết bị, trao đổi mã xác nhận ngang hàng giữa các sinh viên, và tổng hợp lại thành điểm tin cậy. Việc kết hợp nhiều lớp xác minh bổ trợ này giúp bảo đảm tính chính xác và trung thực của kết quả điểm danh mà không đòi hỏi phần cứng chuyên dụng đắt tiền.

Về mặt hệ thống, sản phẩm gồm một Mini App dành cho sinh viên và giảng viên, một trang quản trị web phục vụ phòng đào tạo, và các hàm xử lý phía máy chủ trên nền tảng Firebase. Hệ thống còn cung cấp nhiều tính năng hỗ trợ như cổng máy chiếu hiển thị mã QR cỡ lớn cho lớp đông, giám sát điểm danh theo thời gian thực và quản lý đơn xin nghỉ. Kết quả thử nghiệm cho thấy hệ thống vận hành ổn định và đáp ứng tốt các yêu cầu về chức năng cũng như bảo mật đã đặt ra.

Từ khoá: *điểm danh thông minh, Zalo Mini App, QR động, HMAC-SHA256, xác minh khuôn mặt, Firebase.*

Sinh viên thực hiện

(Ký và ghi rõ họ tên)

ABSTRACT

In most universities today, nearly every student already uses Zalo. Deploying an attendance application directly on the Zalo Mini App platform therefore brings significant convenience: students can check in immediately without installing any additional software. Meanwhile, traditional methods such as oral roll-call or paper sign-in sheets are time-consuming for large classes and cannot reliably guarantee that students are genuinely present.

This thesis presents the design and implementation of a smart attendance system named *Zimo Check-in*, built on the Zalo Mini App platform. The check-in procedure is designed in four steps: scanning a dynamic QR code that is signed with HMAC-SHA256 and refreshed every 30 seconds, verifying the student's face directly on the device, exchanging peer-to-peer confirmation codes among nearby students, and aggregating these results into a trust policy. Combining such complementary verification layers helps ensure accurate and honest attendance records without requiring expensive dedicated hardware.

In terms of architecture, the product comprises a Mini App for students and lecturers, a web-based administration dashboard for the academic office, and server-side functions running on Firebase. It further provides supporting features such as a projector gateway that displays a large QR code for crowded classrooms, real-time attendance monitoring, and leave-request management. Experimental results show that the system operates stably and satisfactorily meets the functional and security requirements defined for it.

Keywords: *smart attendance, Zalo Mini App, rotating QR, HMAC-SHA256, face verification, Firebase.*

GHI CHÚ VỀ VIỆC SỬ DỤNG CÔNG CỤ AI

Trong quá trình thực hiện đồ án, tác giả có sử dụng công cụ trí tuệ nhân tạo (AI) như một trợ lý soạn thảo văn bản và vẽ sơ đồ, dựa trên dữ liệu, mã nguồn và yêu cầu do tác giả cung cấp. Ý tưởng, thiết kế hệ thống, mã nguồn, dữ liệu thực nghiệm và kết quả trong đồ án là do tác giả tự thực hiện. Tác giả đã đọc, kiểm tra, chỉnh sửa và **chịu trách nhiệm về toàn bộ nội dung** của quyển. Mức độ sử dụng AI cho từng hạng mục được liệt kê trong bảng dưới đây.

Công cụ đã sử dụng:

- **Claude (Anthropic)** — trợ lý AI hỗ trợ soạn thảo, biên tập văn bản và tham khảo khi viết mã nguồn.
- **PlantUML** — công cụ sinh sơ đồ (kiến trúc, use case, tuần tự, quy trình) từ đặc tả do tác giả viết.

Quy ước mức độ: *Tự thực hiện* — không sử dụng AI; *Tham khảo AI* — tác giả tự làm, AI góp ý hoặc chỉnh sửa nhẹ; *Dùng AI* — AI tạo ra, tác giả kiểm tra và chỉnh sửa lại.

Hạng mục	Mức độ sử dụng AI
Ý tưởng đề tài, thiết kế hệ thống, giải pháp chống gian lận	Tự thực hiện
Mã nguồn (Mini App, Cloud Functions, trang quản trị)	Tham khảo AI
Ảnh chụp màn hình ứng dụng	Tự thực hiện
Dữ liệu kiểm thử (72 ca), báo cáo bảo mật	Tự thực hiện
Nội dung lý thuyết chuyên môn (HMAC, FaceNet, mã QR)	Tham khảo AI
Bảng biểu, định dạng trình bày	Tham khảo AI
Văn xuôi thuyết minh các chương	Dùng AI
Sơ đồ (kiến trúc, use case, tuần tự, quy trình)	Dùng AI

MỤC LỤC

GHI CHÚ VỀ VIỆC SỬ DỤNG CÔNG CỤ AI	i
CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI.....	1
1.1 Đặt vấn đề.....	1
1.2 Mục tiêu và phạm vi đề tài.....	2
1.3 Định hướng giải pháp.....	3
1.4 Bố cục đồ án	4
CHƯƠNG 2. KHẢO SÁT VÀ PHÂN TÍCH YÊU CẦU.....	5
2.1 Khảo sát hiện trạng	5
2.1.1 Điểm danh thủ công	5
2.1.2 Thẻ từ và thẻ RFID.....	5
2.1.3 Công nghệ NFC	5
2.1.4 Đèn hiệu Bluetooth năng lượng thấp (BLE Beacon)	5
2.1.5 Mã QR tĩnh	5
2.1.6 Nhận diện khuôn mặt	6
2.1.7 So sánh và bài học rút ra.....	6
2.2 Tổng quan chức năng	6
2.2.1 Tác nhân và đối tượng người dùng	6
2.2.2 Biểu đồ use case tổng quát	7
2.2.3 Biểu đồ use case phân rã.....	8
2.2.4 Quy trình nghiệp vụ	9
2.2.5 Yêu cầu chức năng	10
2.3 Đặc tả chức năng	10
2.3.1 Use case của Sinh viên	10
2.3.2 Use case của Giảng viên	14

2.3.3 Use case của Quản trị viên	17
2.4 Yêu cầu phi chức năng	18
CHƯƠNG 3. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG	20
3.1 Nền tảng Zalo Mini App.....	20
3.1.1 Kiến trúc và mô hình hoạt động.....	20
3.1.2 Quy trình xây dựng và phát hành ứng dụng.....	20
3.1.3 Lựa chọn nền tảng và mô hình quyền	22
3.2 Bộ công nghệ phía giao diện.....	23
3.3 Hệ sinh thái Firebase.....	23
3.4 HMAC-SHA256 và mã xác thực thông điệp.....	24
3.5 Nhận diện khuôn mặt và FaceNet	25
3.6 Mã QR và ứng dụng trong điểm danh	26
CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG	28
4.1 Thiết kế kiến trúc.....	28
4.2 Thiết kế chi tiết.....	28
4.2.1 Thiết kế cơ sở dữ liệu Firestore.....	29
4.2.2 Thiết kế luồng xác thực và phân quyền.....	31
4.2.3 Thuật toán mã QR HMAC xoay 30 giây	32
4.2.4 Thiết kế giao diện và bộ nhận diện.....	33
4.2.5 Luồng điểm danh bốn bước cho sinh viên.....	34
4.2.6 Hệ thống chống gian lận nhiều lớp.....	37
4.2.7 Tính năng Cổng máy chiếu (Teacher Display).....	38
4.3 Xây dựng ứng dụng.....	39
4.3.1 Triển khai Mini App.....	39
4.3.2 Triển khai trang quản trị	41

4.3.3 Triển khai Cloud Functions	43
4.4 Kiểm thử và đánh giá	43
4.4.1 Kiểm thử	44
4.4.2 Đánh giá bảo mật	45
4.4.3 Đánh giá hiệu năng	47
4.5 Triển khai và phát hành	47
CHƯƠNG 5. CÁC GIẢI PHÁP VÀ ĐÓNG GÓP NỔI BẬT.....	49
5.1 Cơ chế mã QR HMAC xoay theo thời gian	49
5.2 Cổng máy chiếu và cơ chế pairing one-shot.....	49
5.3 Hệ thống chống gian lận nhiều lớp	50
5.4 Kiến trúc ba vai trò và phân quyền	51
5.5 Tuân thủ chính sách nền tảng Zalo.....	51
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	53
6.1 Kết luận	53
6.2 Hạn chế	53
6.3 Hướng phát triển.....	54
TÀI LIỆU THAM KHẢO.....	57
PHỤ LỤC.....	59
A. HƯỚNG DẪN CÀI ĐẶT VÀ TRIỂN KHAI.....	59
A.1 Yêu cầu môi trường	59
A.2 Cấu trúc mã nguồn.....	59
A.3 Cấu hình biến môi trường	59
A.4 Chạy ở môi trường phát triển.....	60
A.5 Triển khai.....	60
A.6 Khởi tạo và phân quyền	60

B. TRÍCH DẪN MÃ NGUỒN.....	62
B.1 Ký và tạo nội dung mã QR	62
B.2 Sinh mã QR xoay theo thời gian	62
B.3 Bảo mật phía máy chủ: chống phát lại và giới hạn tần suất	63
B.4 Tính điểm tin cậy	64
B.5 Quy tắc bảo mật Firestore	65

DANH MỤC HÌNH VẼ

Hình 2.1	Sơ đồ use case tổng thể của hệ thống	7
Hình 2.2	Use case phân rã – nhóm chức năng của Sinh viên	8
Hình 2.3	Use case phân rã – nhóm quản lý phiên điểm danh của Giảng viên	8
Hình 2.4	Use case phân rã – nhóm quản lý lớp và nhóm quản trị hệ thống	9
Hình 2.5	Quy trình nghiệp vụ tiêu biểu của hệ thống	9
Hình 3.1	Quy trình xây dựng và phát hành một Zalo Mini App	22
Hình 4.1	Kiến trúc tổng thể ba tầng của hệ thống	28
Hình 4.2	Sơ đồ thực thể — liên kết của cơ sở dữ liệu	30
Hình 4.3	Lược đồ trạng thái của phiên và bản ghi điểm danh	31
Hình 4.4	Lược đồ tuần tự sinh và xác minh mã QR HMAC	33
Hình 4.5	Lược đồ hoạt động của quy trình điểm danh	34
Hình 4.6	Lược đồ tuần tự quy trình điểm danh bốn bước	36
Hình 4.7	Lược đồ tuần tự đăng ký khuôn mặt	37
Hình 4.8	Lược đồ tuần tự ghép nối Cổng máy chiếu	39
Hình 4.9	Giao diện Cổng máy chiếu trên trình duyệt	39
Hình 4.10	Sơ đồ phân lớp các thành phần phần mềm của Mini App	40
Hình 4.11	Một số màn hình chính của Mini App	41
Hình 4.12	Bảng điều khiển tổng quan của trang quản trị	42
Hình 4.13	Lược đồ tuần tự xử lý đơn xin nghỉ	42
Hình 4.14	Sơ đồ triển khai vật lý của hệ thống	48

DANH MỤC BẢNG BIỂU

Bảng 2.1	So sánh các phương pháp điểm danh	6
Bảng 2.2	Tổng hợp yêu cầu chức năng theo vai trò	10
Bảng 2.3	Đặc tả use case “Đăng nhập và chọn vai trò”	11
Bảng 2.4	Đặc tả use case “Đăng ký khuôn mặt”	11
Bảng 2.5	Đặc tả use case “Tham gia lớp học”	12
Bảng 2.6	Đặc tả use case “Điểm danh bốn bước”	12
Bảng 2.7	Đặc tả use case “Xem lịch sử điểm danh”	13
Bảng 2.8	Đặc tả use case “Gửi đơn xin nghỉ”	13
Bảng 2.9	Đặc tả use case “Xem lịch học”	13
Bảng 2.10	Đặc tả use case “Sử dụng trợ lý AI”	14
Bảng 2.11	Đặc tả use case “Quản lý lớp học”	14
Bảng 2.12	Đặc tả use case “Tạo và quản lý phiên điểm danh”	15
Bảng 2.13	Đặc tả use case “Hiển thị QR qua Cổng máy chiếu”	15
Bảng 2.14	Đặc tả use case “Giám sát điểm danh thời gian thực”	15
Bảng 2.15	Đặc tả use case “Xem xét và ghi đề kết quả”	16
Bảng 2.16	Đặc tả use case “Điểm danh thủ công”	16
Bảng 2.17	Đặc tả use case “Xem báo cáo gian lận”	16
Bảng 2.18	Đặc tả use case “Xem thống kê lớp học”	17
Bảng 2.19	Đặc tả use case “Quản lý người dùng”	17
Bảng 2.20	Đặc tả use case “Duyệt đơn xin nghỉ”	17
Bảng 2.21	Đặc tả use case “Nhập danh sách từ Excel”	18
Bảng 2.22	Đặc tả use case “Xem bảng điều khiển và quản lý mã mời”	18
Bảng 3.1	So sánh Zalo Mini App với PWA và ứng dụng gốc	22
Bảng 4.1	Các collection chính của cơ sở dữ liệu	29
Bảng 4.2	Cấu trúc collection <code>sessions</code>	29
Bảng 4.3	Cấu trúc collection <code>attendance</code>	29
Bảng 4.4	Cấu trúc collection <code>users</code>	30
Bảng 4.5	Cấu trúc collection <code>classes</code>	30
Bảng 4.6	Ma trận phân quyền theo vai trò	32
Bảng 4.7	Phân loại các hành vi đáng ngờ	37
Bảng 4.8	Phân nhóm các hàm Cloud Functions	43
Bảng 4.9	Phân bổ kịch bản kiểm thử theo nhóm chức năng	44
Bảng 4.10	Một số kịch bản kiểm thử tiêu biểu	45
Bảng 4.11	Bảng điểm đánh giá bảo mật theo lĩnh vực	46

Bảng 4.12	Các lỗ hổng bảo mật đã phát hiện và khắc phục	46
Bảng 5.1	Các lớp xác minh và hình thức gian lận bị ngăn chặn	50
Bảng A.1	Yêu cầu môi trường cài đặt	59

DANH MỤC THUẬT NGỮ VÀ TỪ VIẾT TẮT

Thuật ngữ	Ý nghĩa
API	Application Programming Interface
CNN	Convolutional Neural Network
GPS	Global Positioning System
HMAC	Hash-based Message Authentication Code
HUST	Hanoi University of Science and Technology
JSON	JavaScript Object Notation
QR	Quick Response (code)
SDK	Software Development Kit
UI	User Interface

CHƯƠNG 1. GIỚI THIỆU ĐỀ TÀI

Chương này giới thiệu tổng quan về đề tài. Trước hết, chương đặt vấn đề thông qua bối cảnh hoạt động điểm danh tại các trường đại học cùng những hạn chế của các phương pháp hiện hành. Tiếp đó, chương xác định mục tiêu và phạm vi của đề tài, trình bày định hướng giải pháp cùng các đóng góp chính, và cuối cùng mô tả bố cục của toàn bộ quyển báo cáo.

1.1 Đặt vấn đề

Điểm danh là một hoạt động bắt buộc và diễn ra thường xuyên trong công tác quản lý đào tạo tại các trường đại học. Kết quả điểm danh không chỉ phản ánh ý thức học tập của sinh viên mà còn là một căn cứ để đánh giá điều kiện dự thi theo quy chế đào tạo. Tuy nhiên, cho đến nay phần lớn các lớp học vẫn sử dụng những phương pháp điểm danh truyền thống như gọi tên, ký tên vào danh sách giấy, hoặc chuyển tay phiếu điểm danh. Các phương pháp này tuy đơn giản nhưng tiêu tốn nhiều thời gian của giờ học, đặc biệt với các lớp học phân đông sinh viên, và rất khó kiểm soát tính trung thực.

Nhằm khắc phục các nhược điểm trên, nhiều giải pháp điểm danh ứng dụng công nghệ đã được nghiên cứu và triển khai, bao gồm thẻ từ và thẻ RFID, công nghệ NFC, đèn hiệu Bluetooth năng lượng thấp (BLE Beacon), mã QR, hay nhận diện khuôn mặt. Mỗi giải pháp giải quyết được một phần bài toán nhưng đồng thời cũng bộc lộ những hạn chế riêng về chi phí phần cứng, độ phức tạp khi triển khai hoặc khả năng chống gian lận, sẽ được phân tích chi tiết trong Chương 2.

Song song với sự phát triển của các giải pháp công nghệ, sự phổ biến của điện thoại thông minh và các nền tảng nhắn tin đã tạo ra một cơ hội mới. Tại Việt Nam, Zalo là một trong những ứng dụng nhắn tin phổ biến nhất với hơn 78 triệu người dùng thường xuyên hàng tháng [1], gần như bao phủ toàn bộ nhóm sinh viên. Nền tảng *Zalo Mini App* cho phép xây dựng các ứng dụng chạy trực tiếp bên trong Zalo mà người dùng không cần cài đặt thêm phần mềm, đồng thời cung cấp sẵn cơ chế xác thực người dùng, truy cập máy ảnh, định vị và quét mã QR [2]. Đây là tiền đề thuận lợi để xây dựng một hệ thống điểm danh hiện đại, tiếp cận được số đông sinh viên với chi phí triển khai thấp.

Từ thực tiễn nêu trên, đề tài tập trung giải quyết bốn vấn đề chính mà các hệ thống điểm danh hiện hành tại trường đại học còn gặp phải:

- **Gian lận điểm danh hộ (proxy attendance).** Đây là vấn đề nghiêm trọng nhất: một sinh viên có thể điểm danh thay cho bạn vắng mặt bằng cách ký hộ, chụp

ảnh màn hình mã QR gửi cho nhau, hoặc khai báo hộ thông tin. Phần lớn các phương pháp hiện hành không có cơ chế xác minh danh tính người điểm danh tại thời điểm điểm danh.

- **Tốc độ chậm với lớp học đông.** Với các lớp học phân trên 50 sinh viên, việc gọi tên hoặc ký danh sách có thể chiếm nhiều phút đầu giờ, gây gián đoạn bài giảng và giảm hiệu quả sử dụng thời gian trên lớp.
- **Giảng viên khó giám sát theo thời gian thực.** Giảng viên không có công cụ để theo dõi tiến trình điểm danh ngay khi đang diễn ra, cũng như thiếu báo cáo thống kê dài hạn phục vụ việc đánh giá chuyên cần.
- **Thiếu kênh xin phép nghỉ chính thức.** Sinh viên không có cách gửi đơn xin nghỉ có lý do trong hệ thống, dẫn đến khó khăn khi đối chiếu và xử lý các trường hợp vắng có phép.

Những vấn đề này đặt ra câu hỏi nghiên cứu trọng tâm của đề tài: *làm thế nào kết hợp mã QR động, xác minh sinh trắc học và xác minh ngang hàng giữa các sinh viên để xây dựng một quy trình điểm danh vừa nhanh chóng, thuận tiện, vừa có khả năng chống gian lận cao mà không đòi hỏi phần cứng chuyên dụng đắt tiền?* Việc trả lời câu hỏi này chính là động lực thúc đẩy việc thực hiện đề tài.

1.2 Mục tiêu và phạm vi đề tài

Mục tiêu tổng quát của đề án là xây dựng một hệ thống điểm danh thông minh, chống gian lận, hoạt động trên nền tảng Zalo Mini App, áp dụng được cho môi trường đào tạo đại học. Hệ thống có tên *Zimo Check-in*.

Để đạt được mục tiêu tổng quát, đề án đặt ra các **mục tiêu cụ thể** sau:

1. Xây dựng ứng dụng điểm danh trên Zalo Mini App sử dụng mã QR động xoay theo chu kỳ 30 giây dựa trên thuật toán HMAC-SHA256 nhằm chống việc chụp màn hình và chia sẻ mã.
2. Tích hợp cơ chế xác minh khuôn mặt phía thiết bị người dùng để xác thực danh tính sinh viên tại thời điểm điểm danh.
3. Thiết kế cơ chế xác minh ngang hàng (peer-to-peer) yêu cầu mỗi sinh viên tự quét mã xác nhận của ít nhất một sinh viên xung quanh (chỉ lượt tự quét mới được tính), nhằm chống điểm danh từ xa.
4. Xây dựng trang quản trị web cho giảng viên và phòng đào tạo phục vụ quản lý lớp, giám sát phiên điểm danh theo thời gian thực và xuất báo cáo.
5. Thiết kế hệ thống phát hiện gian lận nhiều lớp với khả năng cảnh báo và lập báo cáo tự động.

Về **ng nghiệp vụ**, hệ thống phục vụ ba nhóm vai trò người dùng: sinh viên, giảng viên và quản trị viên (đại diện cho phòng đào tạo).

Về **kỹ thuật**, phạm vi triển khai gồm: ứng dụng phía người dùng là một Zalo Mini App xây dựng bằng React, TypeScript và thư viện quản lý trạng thái Jotai; trang quản trị là một ứng dụng web; và phần xử lý phía máy chủ dựa trên nền tảng Firebase (Firestore, Cloud Functions, Storage).

Về **quy mô triển khai**, đề án được thực hiện ở mức thử nghiệm (pilot) trong khuôn khổ một đề án tốt nghiệp, chưa triển khai chính thức ở quy mô toàn trường.

Các nội dung nằm ngoài phạm vi của đề án bao gồm: tích hợp với hệ thống quản lý học tập (LMS) của nhà trường, tích hợp thẻ sinh viên RFID, và cơ chế chống giả mạo khuôn mặt bằng kỹ thuật phát hiện sự sống (liveness detection) ở mức nâng cao. Những hạn chế này được trình bày trung thực ở Chương 6.

1.3 Định hướng giải pháp

Để giải quyết những vấn đề nêu trên, đề tài lựa chọn định hướng xây dựng hệ thống điểm danh ngay trên nền tảng Zalo Mini App, tận dụng việc sinh viên đã sẵn có Zalo nên không cần cài đặt ứng dụng mới. Thay vì dựa vào một yếu tố xác minh duy nhất, hệ thống kết hợp nhiều lớp xác minh bổ trợ (mã QR động, khuôn mặt và ngang hàng) theo nguyên lý phòng thủ theo chiều sâu; các nghiệp vụ nhạy cảm được tập trung xử lý phía máy chủ trên nền tảng Firebase nhằm bảo đảm an toàn. Theo định hướng đó, các đóng góp chính của đề án bao gồm:

1. **Cơ chế mã QR động dựa trên HMAC-SHA256 xoay 30 giây**, có đồng bộ đồng hồ giữa nhiều thiết bị (điện thoại của giảng viên và màn hình máy chiếu), giúp chống hiệu quả việc chụp và chia sẻ lại mã QR.
2. **Tính năng “Cổng máy chiếu” (Teacher Display)** cho phép hiển thị mã QR cỡ lớn trên máy chiếu của lớp học, sử dụng cơ chế ghép nối (pairing) bằng mã thông báo 128-bit với quy tắc chuyển trạng thái một chiều, an toàn.
3. **Quy trình điểm danh đa yếu tố bốn bước** (mã QR, khuôn mặt, ngang hàng, định vị) kết hợp thành một hệ thống chống gian lận nhiều lớp theo nguyên lý phòng thủ theo chiều sâu (defense in depth).
4. **Kiến trúc ba vai trò với phân quyền chặt chẽ**, sử dụng quy tắc bảo mật của Firestore kết hợp cơ chế cấp token tùy biến (Custom Token).
5. **Bảo đảm tuân thủ chính sách của nền tảng Zalo**, bao gồm chính sách quyền riêng tư, xử lý dữ liệu sinh trắc học và cơ chế đồng thuận của người dùng.

1.4 Bố cục đề án

Phần còn lại của quyển báo cáo được tổ chức như sau:

- **Chương 2 – Khảo sát và phân tích yêu cầu:** khảo sát các hệ thống điểm danh hiện có, so sánh ưu nhược điểm, phân tích đối tượng người dùng và xác định các yêu cầu chức năng, phi chức năng.
- **Chương 3 – Nền tảng lý thuyết và công nghệ sử dụng:** trình bày các công nghệ và kiến thức nền tảng được áp dụng, gồm nền tảng Zalo Mini App, hệ sinh thái Firebase, thuật toán HMAC-SHA256, nhận diện khuôn mặt và mã QR.
- **Chương 4 – Phân tích thiết kế, triển khai và đánh giá hệ thống:** trình bày kiến trúc tổng thể, thiết kế cơ sở dữ liệu, các thuật toán cốt lõi, quá trình triển khai và kết quả đánh giá về chức năng, bảo mật, hiệu năng.
- **Chương 5 – Các giải pháp và đóng góp nổi bật:** phân tích sâu những giải pháp kỹ thuật tạo nên sự khác biệt của hệ thống.
- **Chương 6 – Kết luận và hướng phát triển:** đánh giá lại những gì đã làm được, chỉ ra các điểm còn hạn chế và phác thảo lộ trình mở rộng.

Kết chương

Chương này đã đặt vấn đề từ bối cảnh và các khó khăn thực tiễn của hoạt động điểm danh, xác định mục tiêu, phạm vi, trình bày định hướng giải pháp cùng những đóng góp chính của đề tài, đồng thời giới thiệu bố cục của quyển báo cáo. Chương tiếp theo sẽ khảo sát các hệ thống điểm danh hiện có và phân tích các yêu cầu đặt ra cho hệ thống cần xây dựng.

CHƯƠNG 2. KHẢO SÁT VÀ PHÂN TÍCH YÊU CẦU

Chương này khảo sát hiện trạng các hệ thống điểm danh, phân tích tổng quan chức năng của hệ thống cần xây dựng thông qua các tác nhân và ca sử dụng, đặc tả chi tiết các chức năng, và cuối cùng xác định các yêu cầu phi chức năng làm căn cứ cho việc thiết kế ở các chương sau.

2.1 Khảo sát hiện trạng

Có thể phân loại các phương pháp điểm danh đang được sử dụng thành sáu nhóm chính, từ thủ công đến tự động hoá bằng công nghệ.

2.1.1 Điểm danh thủ công

Đây là phương pháp truyền thống nhất: giảng viên gọi tên hoặc cho sinh viên ký vào danh sách giấy. Ưu điểm là đơn giản, không cần thiết bị. Tuy nhiên phương pháp này tốn nhiều thời gian với lớp đông, dễ bị ký hộ, và kết quả ở dạng giấy nên khó thống kê, lưu trữ và tra cứu về sau.

2.1.2 Thẻ từ và thẻ RFID

Sinh viên quét thẻ qua đầu đọc để ghi nhận sự hiện diện. Phương pháp này nhanh và tự động hoá việc lưu trữ, nhưng đòi hỏi chi phí đầu tư đầu đọc và thẻ, đồng thời vẫn tồn tại nguy cơ quét hộ thẻ cho bạn vắng mặt vì thẻ không gắn với danh tính sinh trắc học [3].

2.1.3 Công nghệ NFC

NFC hoạt động tương tự RFID nhưng tích hợp sẵn trên điện thoại thông minh, cho phép chạm điện thoại vào thẻ hoặc thiết bị để điểm danh. Ưu điểm là tận dụng thiết bị cá nhân, song không phải điện thoại nào cũng hỗ trợ NFC và vẫn chưa giải quyết được vấn đề xác minh danh tính [4].

2.1.4 Đèn hiệu Bluetooth năng lượng thấp (BLE Beacon)

Một thiết bị beacon đặt trong phòng học phát tín hiệu Bluetooth; ứng dụng trên điện thoại sinh viên phát hiện tín hiệu để xác nhận sự hiện diện trong phạm vi lớp học. Phương pháp này thuận tiện và xác định được vị trí tương đối, nhưng phải trang bị beacon cho từng phòng và tín hiệu có thể bị bắt từ ngoài phòng, dẫn tới điểm danh sai [5], [6].

2.1.5 Mã QR tĩnh

Giảng viên hiển thị một mã QR cố định để sinh viên quét và điểm danh. Cách này rẻ và nhanh, không cần phần cứng chuyên dụng. Tuy nhiên nhược điểm lớn nhất là mã QR tĩnh có thể bị chụp màn hình và chia sẻ cho sinh viên vắng mặt quét

từ xa, làm mất hoàn toàn ý nghĩa chống gian lận.

2.1.6 Nhận diện khuôn mặt

Hệ thống dùng camera và mô hình học sâu để nhận diện khuôn mặt sinh viên. Phương pháp này xác thực được danh tính, chống điểm danh hộ tốt. Tuy nhiên nếu triển khai tập trung bằng camera tại lớp thì chi phí cao, còn nếu chỉ dựa vào ảnh tĩnh thì có thể bị qua mặt bằng ảnh chụp nếu thiếu cơ chế phát hiện sự sống (liveness) [7].

2.1.7 So sánh và bài học rút ra

Bảng 2.1 so sánh sáu phương án trên theo các tiêu chí quan trọng. Mức đánh giá được quy ước: *Thấp / Trung bình (TB) / Cao*, hoặc *Có / Không*.

Bảng 2.1: So sánh các phương pháp điểm danh

Phương án	Chi phí phần cứng	Độ phức tạp triển khai	Chống gian lận	Trải nghiệm sinh viên	Cần TB riêng
Thủ công	Thấp	Thấp	Thấp	Thấp	Không
RFID / thẻ từ	Cao	TB	TB	TB	Có
NFC	TB	TB	TB	TB	Có
BLE Beacon	TB	Cao	TB	Cao	Có
QR tĩnh	Thấp	Thấp	Thấp	Cao	Không
Nhận diện mặt	Cao	Cao	Cao	TB	Tùy

Từ bảng so sánh có thể rút ra hai bài học quan trọng. Thứ nhất, **không có phương án đơn lẻ nào vừa rẻ, vừa thuận tiện, vừa chống gian lận tốt**: các phương án rẻ và thuận tiện (QR tĩnh) lại yếu về chống gian lận, trong khi các phương án chống gian lận tốt (nhận diện mặt) lại đắt hoặc phức tạp. Thứ hai, để đạt khả năng chống gian lận cao mà vẫn giữ chi phí thấp, cần **kết hợp nhiều lớp xác minh** bổ trợ cho nhau thay vì dựa vào một cơ chế duy nhất. Đây chính là định hướng thiết kế của hệ thống trong đồ án.

2.2 Tổng quan chức năng

2.2.1 Tác nhân và đối tượng người dùng

Hệ thống có ba tác nhân (actor), tương ứng ba nhóm người dùng với đặc điểm và kỳ vọng khác nhau:

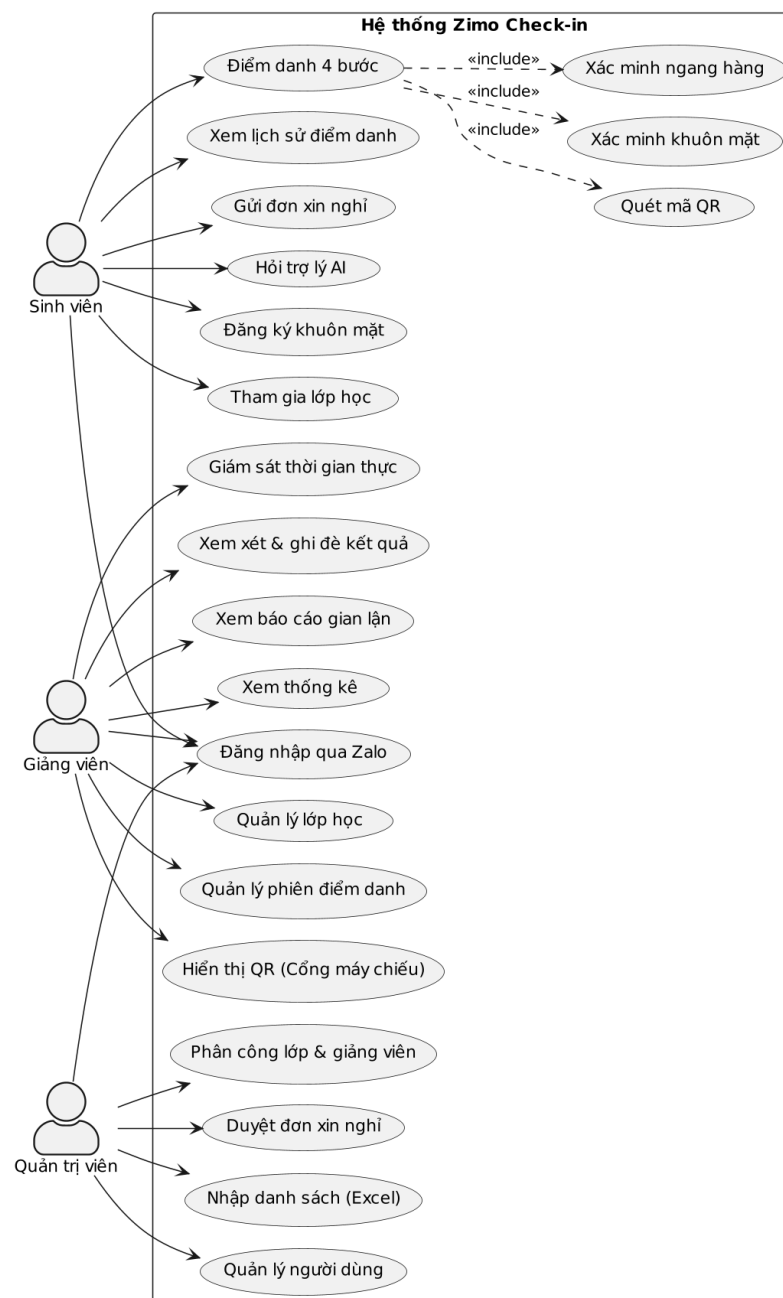
- **Sinh viên** là người dùng đông nhất. Họ kỳ vọng thao tác điểm danh nhanh (chỉ vài giây), không tốn nhiều dung lượng mạng, giao diện thân thiện trên điện thoại và không phải cài thêm ứng dụng.
- **Giảng viên** cần công cụ tạo và quản lý phiên điểm danh, giám sát tiến trình theo thời gian thực, xử lý các trường hợp ngoại lệ (điểm danh thủ công, duyệt

lại) và xem báo cáo chuyên cần.

- **Quản trị viên** (phòng đào tạo) cần quản lý dữ liệu ở quy mô lớn: nhập danh sách sinh viên và lớp hàng loạt, phân công sinh viên vào lớp, duyệt đơn xin nghỉ và xem thống kê tổng hợp toàn hệ thống.

2.2.2 Biểu đồ use case tổng quát

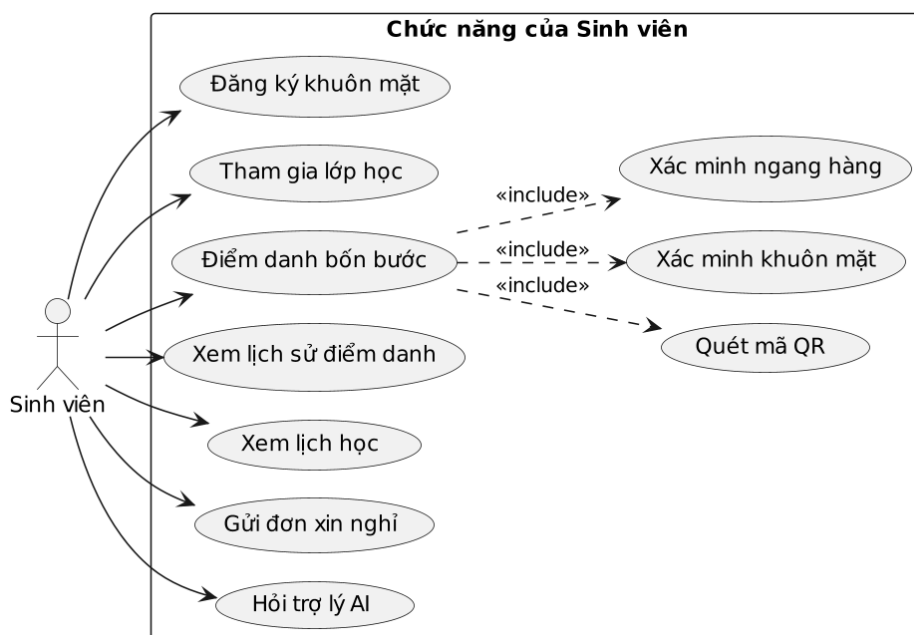
Mỗi tác nhân tương tác với một tập các ca sử dụng (use case) phản ánh các yêu cầu chức năng của hệ thống. Sơ đồ use case tổng quát được trình bày trong Hình 2.1; đặc tả chi tiết từng use case được trình bày ở mục 2.3.



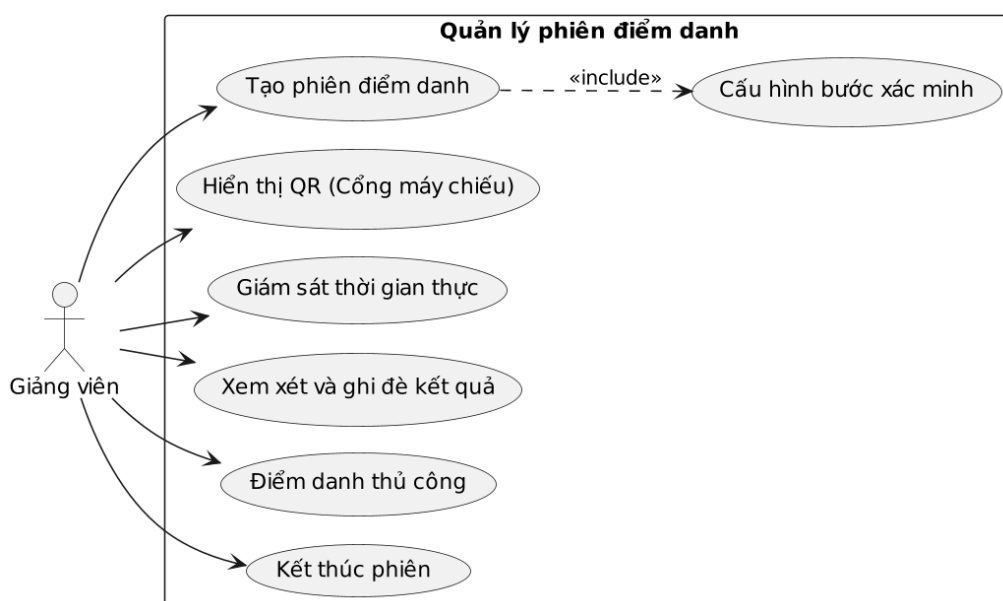
Hình 2.1: Sơ đồ use case tổng thể của hệ thống

2.2.3 Biểu đồ use case phân rã

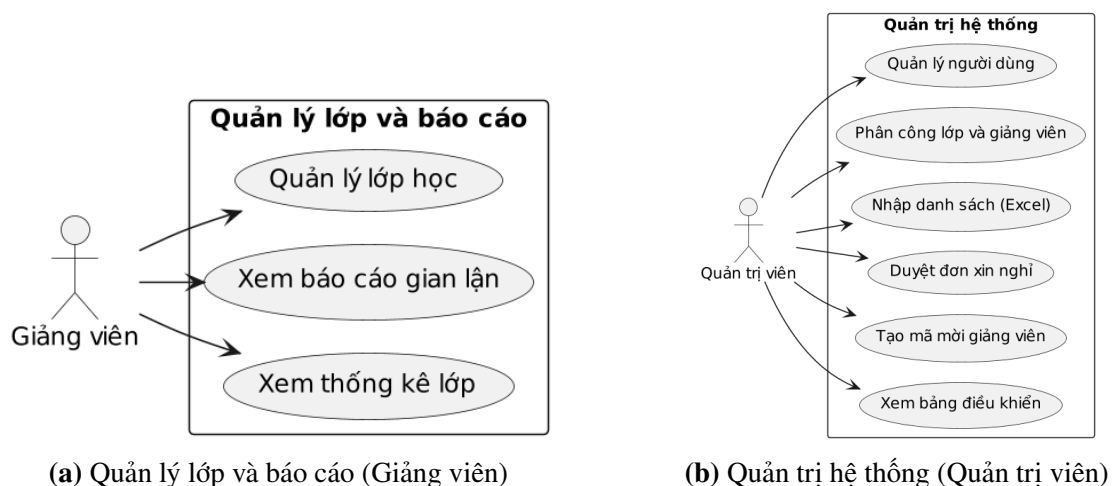
Để làm rõ phạm vi chức năng của từng tác nhân, sơ đồ use case tổng quát được phân rã theo bốn nhóm: nhóm chức năng của sinh viên (Hình 2.2), nhóm quản lý phiên điểm danh của giảng viên (Hình 2.3), nhóm quản lý lớp và báo cáo của giảng viên (Hình 2.4a) cùng nhóm quản trị hệ thống của quản trị viên (Hình 2.4b). Hai nhóm sau được trình bày chung trong Hình 2.4.



Hình 2.2: Use case phân rã – nhóm chức năng của Sinh viên



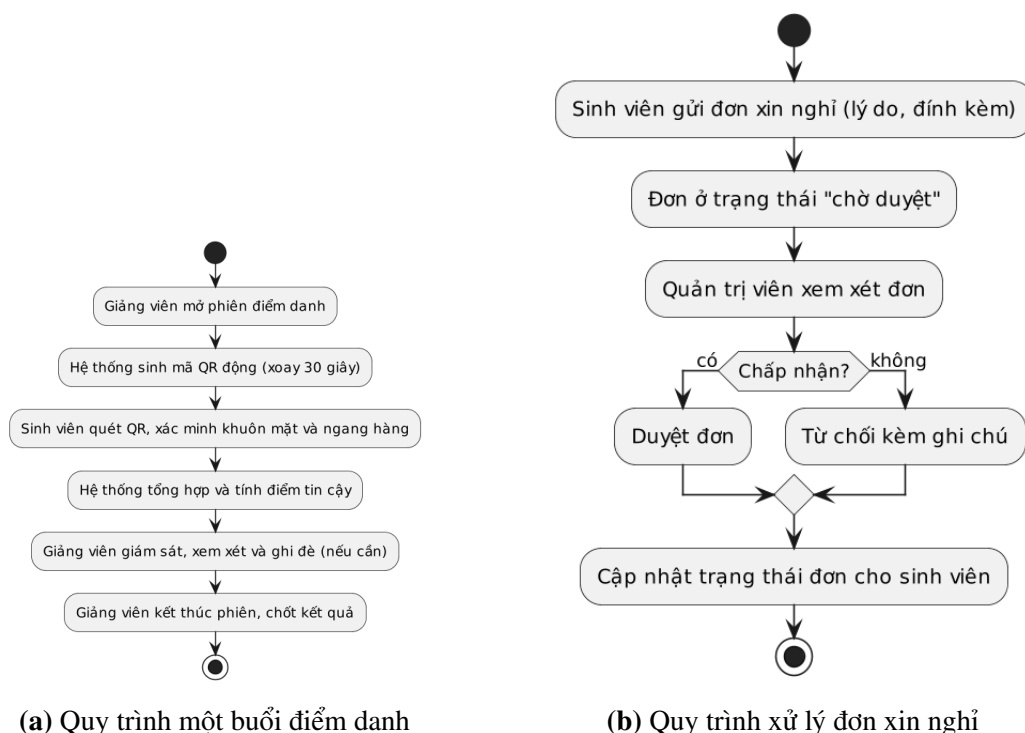
Hình 2.3: Use case phân rã – nhóm quản lý phiên điểm danh của Giảng viên



Hình 2.4: Use case phân rã – nhóm quản lý lớp và nhóm quản trị hệ thống

2.2.4 Quy trình nghiệp vụ

Bên cạnh các use case rời rạc, hai quy trình nghiệp vụ tiêu biểu của hệ thống được mô tả dưới dạng biểu đồ hoạt động trong Hình 2.5. Hình 2.5a mô tả quy trình một buổi điểm danh từ khi giảng viên mở phiên đến khi chốt kết quả; Hình 2.5b mô tả quy trình xử lý đơn xin nghỉ với sự tham gia của sinh viên và quản trị viên.



Hình 2.5: Quy trình nghiệp vụ tiêu biểu của hệ thống

2.2.5 Yêu cầu chức năng

Trên cơ sở phân tích đối tượng người dùng và sơ đồ use case, các yêu cầu chức năng (Functional Requirement – FR) của hệ thống được tổng hợp theo ba vai trò trong Bảng 2.2.

Bảng 2.2: Tổng hợp yêu cầu chức năng theo vai trò

Mã	Mô tả chức năng
Sinh viên	
FR-S.1	Đăng nhập bằng tài khoản Zalo và xác minh email sinh viên của trường
FR-S.2	Đăng ký khuôn mặt phục vụ xác minh danh tính
FR-S.3	Xem danh sách lớp và lịch học của bản thân
FR-S.4	Thực hiện điểm danh theo quy trình bốn bước (QR, khuôn mặt, ngang hàng, vị trí)
FR-S.5	Xem lịch sử điểm danh và trạng thái chuyên cần
FR-S.6	Gửi đơn xin nghỉ có lý do
FR-S.7	Sử dụng trợ lý hỏi đáp (AI Chat)
Giảng viên	
FR-T.1	Tạo lớp học phần hoặc tham gia bằng mã mời
FR-T.2	Tạo phiên điểm danh, tùy chọn bật/tắt các bước xác minh
FR-T.3	Hiển thị mã QR qua tính năng Cổng máy chiếu
FR-T.4	Giám sát phiên điểm danh theo thời gian thực
FR-T.5	Điểm danh thủ công và duyệt lại kết quả điểm danh
FR-T.6	Xem báo cáo gian lận của lớp
Quản trị viên	
FR-A.1	Quản lý người dùng và tài khoản
FR-A.2	Quản lý lớp học và phân công sinh viên hàng loạt (nhập từ Excel)
FR-A.3	Duyệt đơn xin nghỉ của sinh viên
FR-A.4	Xem bảng thống kê tổng hợp (dashboard)
FR-A.5	Quản lý mã mời giảng viên và báo cáo gian lận

2.3 Đặc tả chức năng

Phần này đặc tả chi tiết các use case chính của hệ thống. Mỗi use case được mô tả theo cấu trúc thống nhất: mã, tác nhân, mô tả, tiền điều kiện, luồng sự kiện chính, luồng ngoại lệ và hậu điều kiện.

2.3.1 Use case của Sinh viên

Các use case của sinh viên được đặc tả lần lượt trong: Bảng 2.3 (đăng nhập và chọn vai trò), Bảng 2.4 (đăng ký khuôn mặt), Bảng 2.5 (tham gia lớp học), Bảng 2.6 (điểm danh bốn bước), Bảng 2.7 (xem lịch sử điểm danh), Bảng 2.8 (gửi đơn xin nghỉ), Bảng 2.9 (xem lịch học) và Bảng 2.10 (sử dụng trợ lý AI).

Bảng 2.3: Đặc tả use case “Đăng nhập và chọn vai trò”

Mã use case	UC-01
Tác nhân	Sinh viên, Giảng viên, Quản trị viên
Mô tả	Người dùng đăng nhập qua tài khoản Zalo và chọn vai trò để truy cập hệ thống.
Tiền điều kiện	Đã cài đặt Zalo và mở Mini App.
Luồng chính	1. Người dùng mở ứng dụng. 2. Hệ thống lấy định danh Zalo. 3. Người dùng chọn vai trò Sinh viên hoặc Giảng viên. 4. Nếu là sinh viên, nhập MSSV hợp lệ (8 chữ số, bắt đầu “20”). 5. Hệ thống lưu hồ sơ và chuyển vào trang chủ tương ứng vai trò.
Luồng ngoại lệ	MSSV sai định dạng: hệ thống báo lỗi và yêu cầu nhập lại. Người dùng từ chối cấp quyền Zalo: một số chức năng bị hạn chế.
Hậu điều kiện	Phiên đăng nhập được thiết lập; vai trò được lưu.

Bảng 2.4: Đặc tả use case “Đăng ký khuôn mặt”

Mã use case	UC-02
Tác nhân	Sinh viên
Mô tả	Sinh viên đăng ký dữ liệu khuôn mặt phục vụ xác minh khi điểm danh.
Tiền điều kiện	Tài khoản sinh viên đã đăng nhập và quyền máy ảnh đã được cấp.
Luồng chính	1. Sinh viên mở chức năng đăng ký khuôn mặt. 2. Ứng dụng tải mô hình nhận diện. 3. Sinh viên chụp hai ảnh khuôn mặt. 4. Ứng dụng trích véc-tơ đặc trưng 128 chiều và so khớp hai ảnh (khoảng cách $< 0,6$). 5. Hệ thống lưu véc-tơ đặc trưng.
Luồng ngoại lệ	Không phát hiện được khuôn mặt hoặc hai ảnh không khớp: yêu cầu chụp lại.
Hậu điều kiện	Thuộc tính <code>faceRegistered</code> được đặt true; véc-tơ đặc trưng được lưu.

Bảng 2.5: Đặc tả use case “Tham gia lớp học”

Mã use case	UC-03
Tác nhân	Sinh viên
Mô tả	Sinh viên tham gia một lớp học phần bằng mã lớp do giảng viên cung cấp.
Tiền điều kiện	Sinh viên đã đăng nhập và được giảng viên cung cấp mã lớp.
Luồng chính	1. Sinh viên nhập mã lớp được cung cấp. 2. Máy chủ đối chiếu mã lớp với cơ sở dữ liệu và xác nhận còn hiệu lực. 3. Sinh viên được ghi danh vào lớp tương ứng.
Luồng ngoại lệ	Mã lớp không tồn tại hoặc sai định dạng: báo lỗi. Sinh viên đã ở trong lớp: thông báo đã tham gia.
Hậu điều kiện	Sinh viên có trong danh sách của lớp.

Bảng 2.6: Đặc tả use case “Điểm danh bốn bước”

Mã use case	UC-04
Tác nhân	Sinh viên
Mô tả	Sinh viên thực hiện điểm danh qua bốn bước: quét mã QR, xác minh khuôn mặt, xác minh ngang hàng và hoàn tất.
Tiền điều kiện	Đã đăng nhập, đã đăng ký khuôn mặt, đang ở trong lớp và phiên điểm danh đang mở.
Luồng chính	1. Sinh viên quét mã QR động của giảng viên; hệ thống kiểm tra chữ ký HMAC và thời gian. 2. Ứng dụng tự động chụp và so khớp khuôn mặt (đạt khi độ tin cậy $\geq 0,7$). 3. Sinh viên tự quét mã QR của ít nhất một bạn xung quanh (chỉ lượt tự quét mới được tính). 4. Hệ thống tổng hợp kết quả, tính điểm tin cậy và lưu bản ghi điểm danh.
Luồng ngoại lệ	Mã QR hết hạn/sai chữ ký: từ chối. Khuôn mặt không khớp hoặc số lượt ngang hàng < 1 : kết quả chuyển trạng thái “cần xem xét”.
Hậu điều kiện	Bản ghi điểm danh được lưu kèm điểm tin cậy (present/re-view/absent).

Bảng 2.7: Đặc tả use case “Xem lịch sử điểm danh”

Mã use case	UC-05
Tác nhân	Sinh viên
Mô tả	Sinh viên xem lại lịch sử điểm danh của mình theo lớp và thời gian.
Tiền điều kiện	Sinh viên đã đăng nhập và có sẵn bản ghi điểm danh các buổi trước.
Luồng chính	1. Sinh viên mở trang lịch sử. 2. Hệ thống hiển thị danh sách bản ghi kèm điểm tin cậy. 3. Sinh viên lọc theo lớp hoặc khoảng thời gian.
Luồng ngoại lệ	Chưa có dữ liệu: hiển thị trạng thái trống.
Hậu điều kiện	Không thay đổi dữ liệu.

Bảng 2.8: Đặc tả use case “Gửi đơn xin nghỉ”

Mã use case	UC-06
Tác nhân	Sinh viên
Mô tả	Sinh viên gửi đơn xin nghỉ buổi học kèm lý do và tệp đính kèm.
Tiền điều kiện	Sinh viên đã đăng nhập và đang tham gia lớp có buổi cần xin nghỉ.
Luồng chính	1. Sinh viên chọn lớp/buổi cần xin nghỉ. 2. Nhập lý do và đính kèm minh chứng (nếu có). 3. Gửi đơn; hệ thống lưu đơn với trạng thái “chờ duyệt”.
Luồng ngoại lệ	Thiếu thông tin bắt buộc: báo lỗi.
Hậu điều kiện	Đơn xin nghỉ được tạo với trạng thái chờ duyệt.

Bảng 2.9: Đặc tả use case “Xem lịch học”

Mã use case	UC-17
Tác nhân	Sinh viên
Mô tả	Sinh viên xem thời khoá biểu các lớp đã tham gia.
Tiền điều kiện	Sinh viên đã đăng nhập và đã tham gia ít nhất một lớp học phần.
Luồng chính	1. Sinh viên mở trang lịch học. 2. Hệ thống hiển thị lịch theo ngày/tuần kèm phòng học và thời gian.
Luồng ngoại lệ	Chưa tham gia lớp nào: hiển thị trạng thái trống.
Hậu điều kiện	Không thay đổi dữ liệu.

Bảng 2.10: Đặc tả use case “Sử dụng trợ lý AI”

Mã use case	UC-18
Tác nhân	Sinh viên
Mô tả	Sinh viên hỏi đáp với trợ lý AI về thông tin liên quan đến điểm danh và lịch học.
Tiền điều kiện	Đã đăng nhập.
Luồng chính	1. Sinh viên mở trang trợ lý AI. 2. Nhập câu hỏi. 3. Hệ thống gọi mô hình ngôn ngữ qua Cloud Function và trả lời.
Luồng ngoại lệ	Dịch vụ AI gặp lỗi: thông báo và cho phép thử lại.
Hậu điều kiện	Không thay đổi dữ liệu nghiệp vụ.

2.3.2 Use case của Giảng viên

Các use case của giảng viên được đặc tả lần lượt trong: Bảng 2.11 (quản lý lớp học), Bảng 2.12 (tạo và quản lý phiên điểm danh), Bảng 2.13 (hiển thị QR qua Cổng máy chiếu), Bảng 2.14 (giám sát điểm danh thời gian thực), Bảng 2.15 (xem xét và ghi đề kết quả), Bảng 2.16 (điểm danh thủ công), Bảng 2.17 (xem báo cáo gian lận) và Bảng 2.18 (xem thống kê lớp học).

Bảng 2.11: Đặc tả use case “Quản lý lớp học”

Mã use case	UC-07
Tác nhân	Giảng viên
Mô tả	Giảng viên tạo lớp học phần, cấu hình lịch học và quản lý danh sách sinh viên.
Tiền điều kiện	Đã đăng nhập vai trò giảng viên.
Luồng chính	1. Giảng viên tạo lớp với tên, mã, lịch học. 2. Hệ thống sinh mã lớp để sinh viên tham gia. 3. Giảng viên xem và quản lý danh sách sinh viên trong lớp.
Luồng ngoại lệ	Thông tin lớp không hợp lệ: báo lỗi.
Hậu điều kiện	Lớp học được tạo và sẵn sàng cho điểm danh.

Bảng 2.12: Đặc tả use case “Tạo và quản lý phiên điểm danh”

Mã use case	UC-08
Tác nhân	Giảng viên
Mô tả	Giảng viên mở một phiên điểm danh cho lớp, cấu hình các yêu cầu xác minh và kết thúc phiên.
Tiền điều kiện	Đã đăng nhập vai trò giảng viên và có ít nhất một lớp.
Luồng chính	1. Giảng viên chọn lớp và mở phiên. 2. Cấu hình thời lượng, bật/tắt xác minh khuôn mặt và ngang hàng. 3. Hệ thống sinh khoá bí mật HMAC và hiển thị mã QR động xoay 30 giây. 4. Khi buổi học kết thúc, giảng viên đóng phiên điểm danh.
Luồng ngoại lệ	Đã có phiên đang mở: yêu cầu kết thúc trước khi mở phiên mới.
Hậu điều kiện	Phiên điểm danh được tạo (active) hoặc kết thúc (ended).

Bảng 2.13: Đặc tả use case “Hiển thị QR qua Cổng máy chiếu”

Mã use case	UC-09
Tác nhân	Giảng viên
Mô tả	Giảng viên liên kết phiên điểm danh với màn hình máy chiếu để hiển thị mã QR cỡ lớn.
Tiền điều kiện	Đang có phiên điểm danh mở; trang Cổng máy chiếu đang hiển thị mã ghép nối.
Luồng chính	1. Trang máy chiếu sinh mã ghép nối (hết hạn 60 giây). 2. Giảng viên quét mã ghép nối bằng Mini App. 3. Hệ thống chuyển mã sang trạng thái “paired” và gắn phiên. 4. Máy chiếu hiển thị mã QR điểm danh cỡ lớn, đồng bộ với phiên.
Luồng ngoại lệ	Mã ghép nối hết hạn hoặc đã được ghép: yêu cầu sinh mã mới.
Hậu điều kiện	Máy chiếu hiển thị mã QR đồng bộ với phiên của giảng viên.

Bảng 2.14: Đặc tả use case “Giám sát điểm danh thời gian thực”

Mã use case	UC-10
Tác nhân	Giảng viên
Mô tả	Giảng viên theo dõi tiến trình điểm danh của sinh viên theo thời gian thực.
Tiền điều kiện	Đang có phiên điểm danh mở.
Luồng chính	1. Giảng viên mở màn hình giám sát. 2. Hệ thống hiển thị danh sách sinh viên kèm điểm tin cậy, số lượt ngang hàng và khoảng cách GPS, cập nhật tức thời. 3. Giảng viên lọc theo trạng thái khi cần.
Luồng ngoại lệ	Mất kết nối mạng: hiển thị trạng thái ngoại tuyến và đồng bộ lại khi có mạng.
Hậu điều kiện	Không thay đổi dữ liệu điểm danh.

Bảng 2.15: Đặc tả use case “Xem xét và ghi đề kết quả”

Mã use case	UC-11
Tác nhân	Giảng viên
Mô tả	Giảng viên xem xét các bản ghi “cần xem xét” và ghi đề trạng thái khi cần.
Tiền điều kiện	Phiên điểm danh đã hoặc đang diễn ra.
Luồng chính	1. Giảng viên mở trang xem xét. 2. Hệ thống hiển thị bản ghi kèm độ tin cậy khuôn mặt và lý do. 3. Giảng viên ghi đề thành “có mặt” hoặc “vắng” kèm lý do.
Luồng ngoại lệ	Không có bản ghi cần xem xét: hiển thị trạng thái trống.
Hậu điều kiện	Trạng thái điểm danh được cập nhật kèm thông tin ghi đề.

Bảng 2.16: Đặc tả use case “Điểm danh thủ công”

Mã use case	UC-12
Tác nhân	Giảng viên
Mô tả	Giảng viên điểm danh thủ công cho sinh viên trong trường hợp đặc biệt.
Tiền điều kiện	Phiên điểm danh đang mở hoặc vừa kết thúc.
Luồng chính	1. Giảng viên chọn sinh viên cần điểm danh thủ công. 2. Nhập lý do (nếu có). 3. Hệ thống ghi nhận có mặt kèm thông tin người thực hiện.
Luồng ngoại lệ	Hủy điểm danh thủ công: hệ thống khôi phục trạng thái trước đó.
Hậu điều kiện	Bản ghi điểm danh thủ công được lưu kèm người thực hiện và thời điểm.

Bảng 2.17: Đặc tả use case “Xem báo cáo gian lận”

Mã use case	UC-13
Tác nhân	Giảng viên
Mô tả	Giảng viên xem báo cáo các hành vi điểm danh đáng ngờ do hệ thống phân tích.
Tiền điều kiện	Đã có dữ liệu điểm danh để phân tích.
Luồng chính	1. Giảng viên mở trang báo cáo gian lận. 2. Hệ thống chạy phân tích và liệt kê các mẫu đáng ngờ kèm mức độ. 3. Giảng viên xuất báo cáo ra tệp CSV.
Luồng ngoại lệ	Không phát hiện hành vi đáng ngờ: hiển thị báo cáo trống.
Hậu điều kiện	Báo cáo gian lận được tạo và có thể xuất ra tệp.

Bảng 2.18: Đặc tả use case “Xem thống kê lớp học”

Mã use case	UC-19
Tác nhân	Giảng viên
Mô tả	Giảng viên xem thống kê chuyên cần của lớp (có mặt/xem xét/vắng) dưới dạng biểu đồ.
Tiền điều kiện	Có dữ liệu điểm danh của lớp.
Luồng chính	1. Giảng viên mở trang thống kê. 2. Hệ thống tổng hợp và hiển thị biểu đồ theo phiên và theo sinh viên.
Luồng ngoại lệ	Chưa có dữ liệu: hiển thị trạng thái trống.
Hậu điều kiện	Không thay đổi dữ liệu.

2.3.3 Use case của Quản trị viên

Các use case của quản trị viên được đặc tả lần lượt trong: Bảng 2.19 (quản lý người dùng), Bảng 2.20 (duyet đơn xin nghỉ), Bảng 2.21 (nhập danh sách từ Excel) và Bảng 2.22 (xem bảng điều khiển và quản lý mã mời).

Bảng 2.19: Đặc tả use case “Quản lý người dùng”

Mã use case	UC-14
Tác nhân	Quản trị viên
Mô tả	Quản trị viên quản lý tài khoản người dùng và gán vai trò giảng viên.
Tiền điều kiện	Quản trị viên đã xác thực và truy cập được trang quản trị web.
Luồng chính	1. Quản trị viên tìm kiếm, lọc người dùng theo vai trò. 2. Tạo mã mời hoặc gán vai trò giảng viên. 3. Hệ thống cập nhật vai trò ở phía máy chủ.
Luồng ngoại lệ	Thao tác trái phép bị quy tắc bảo mật từ chối.
Hậu điều kiện	Vai trò người dùng được cập nhật an toàn.

Bảng 2.20: Đặc tả use case “Duyệt đơn xin nghỉ”

Mã use case	UC-15
Tác nhân	Quản trị viên
Mô tả	Quản trị viên xem xét và phê duyệt hoặc từ chối các đơn xin nghỉ của sinh viên.
Tiền điều kiện	Có đơn xin nghỉ ở trạng thái chờ duyệt.
Luồng chính	1. Quản trị viên mở danh sách đơn chờ duyệt. 2. Xem lý do và minh chứng đính kèm. 3. Phê duyệt hoặc từ chối kèm ghi chú.
Luồng ngoại lệ	Không có đơn chờ duyệt: hiển thị trạng thái trống.
Hậu điều kiện	Trạng thái đơn được cập nhật (đã duyệt/từ chối).

Bảng 2.21: Đặc tả use case “Nhập danh sách từ Excel”

Mã use case	UC-16
Tác nhân	Quản trị viên
Mô tả	Quản trị viên nhập danh sách sinh viên hoặc lớp hàng loạt từ tệp Excel.
Tiền điều kiện	Đã đăng nhập trang quản trị; có tệp Excel đúng định dạng.
Luồng chính	1. Quản trị viên tải lên tệp Excel. 2. Hệ thống đọc và kiểm tra dữ liệu. 3. Hệ thống tạo hàng loạt bản ghi tương ứng.
Luồng ngoại lệ	Tệp sai định dạng hoặc dữ liệu lỗi: báo lỗi và bỏ qua dòng lỗi.
Hậu điều kiện	Dữ liệu được nhập vào hệ thống.

Bảng 2.22: Đặc tả use case “Xem bảng điều khiển và quản lý mã mời”

Mã use case	UC-20
Tác nhân	Quản trị viên
Mô tả	Quản trị viên xem tổng kê tổng hợp toàn hệ thống và tạo, quản lý mã mời giảng viên.
Tiền điều kiện	Đã đăng nhập trang quản trị.
Luồng chính	1. Quản trị viên mở bảng điều khiển. 2. Xem các số liệu tổng hợp. 3. Tạo mã mời giảng viên có thời hạn.
Luồng ngoại lệ	Chưa có dữ liệu: hiển thị trạng thái trống.
Hậu điều kiện	Mã mời được tạo; vai trò giảng viên được gán khi mã được sử dụng.

2.4 Yêu cầu phi chức năng

Ngoài các chức năng nghiệp vụ, hệ thống phải đáp ứng các yêu cầu phi chức năng (Non-Functional Requirement – NFR) sau:

- **Bảo mật.** Mã QR phải được ký bằng HMAC-SHA256 và chống phát lại; mọi thao tác ghi dữ liệu quan trọng phải được kiểm soát bằng quy tắc bảo mật của Firestore và xử lý phía máy chủ; khoá bí mật và khoá API không được lộ phía thiết bị người dùng.
- **Hiệu năng.** Thời gian khởi động ứng dụng và thao tác quét QR phải đủ nhanh để không gây gián đoạn giờ học; dữ liệu phiên điểm danh được đồng bộ theo thời gian thực.
- **Khả năng mở rộng.** Hệ thống cần phục vụ được số lượng lớn sinh viên nhờ khả năng tự co giãn của Firestore.
- **Tính sẵn sàng và hoạt động ngoại tuyến.** Hệ thống cần có hàng đợi xử lý ngoại tuyến (offline queue) để không mất dữ liệu khi mạng chập chờn.

- **Trải nghiệm người dùng.** Giao diện tối ưu cho điện thoại, nhất quán với bộ nhận diện của trường, thao tác tối giản.
- **Tuân thủ.** Hệ thống tuân thủ chính sách kiểm duyệt của nền tảng Zalo và các quy định về quyền riêng tư, đặc biệt với dữ liệu khuôn mặt.

Mức độ đáp ứng các yêu cầu bảo mật được đánh giá định lượng theo một bộ tiêu chí 10 lĩnh vực và trình bày chi tiết ở Chương 4.

Bên cạnh các yêu cầu trên, hệ thống còn chịu một số **ràng buộc** về nền tảng và phạm vi:

- **Ràng buộc nền tảng.** Ứng dụng phía người dùng phải chạy trong môi trường Zalo Mini App, do đó bị giới hạn bởi bộ API và chính sách của nền tảng; phần xử lý phía máy chủ vận hành trên gói miễn phí của Firebase trong giai đoạn thử nghiệm.
- **Ràng buộc thiết bị.** Quy trình điểm danh yêu cầu thiết bị có máy ảnh và kết nối Internet; bước xác minh ngang hàng cần tối thiểu hai thiết bị sinh viên ở gần nhau (bản thân và một bạn).
- **Ràng buộc phạm vi.** Trong khuôn khổ một đề án tốt nghiệp, hệ thống được triển khai ở mức thử nghiệm, chưa tích hợp với hệ thống quản lý đào tạo của trường và chưa hỗ trợ thẻ sinh viên RFID/NFC.

Kết chương

Chương này đã khảo sát sáu phương pháp điểm danh hiện có và chỉ ra rằng cần kết hợp nhiều lớp xác minh để vừa chống gian lận tốt vừa giữ chi phí hợp lý. Trên cơ sở phân tích các tác nhân, sơ đồ use case và đặc tả chức năng, chương đã xác định đầy đủ các yêu cầu chức năng và phi chức năng của hệ thống. Chương tiếp theo trình bày các công nghệ và nền tảng lý thuyết được sử dụng để hiện thực hoá các yêu cầu này.

CHƯƠNG 3. NỀN TẢNG LÝ THUYẾT VÀ CÔNG NGHỆ SỬ DỤNG

Chương này trình bày các công nghệ và nền tảng lý thuyết được sử dụng để xây dựng hệ thống, kèm theo lý do lựa chọn so với các phương án thay thế. Các nội dung gồm: nền tảng Zalo Mini App, bộ công nghệ phía giao diện, hệ sinh thái Firebase, thuật toán HMAC-SHA256, nhận diện khuôn mặt và mã QR.

3.1 Nền tảng Zalo Mini App

Zalo Mini App là nền tảng cho phép xây dựng các ứng dụng chạy trực tiếp bên trong ứng dụng Zalo mà không cần cài đặt riêng. Về bản chất, một Mini App là một ứng dụng web chạy trong môi trường WebView do Zalo cung cấp, được bổ sung một bộ công cụ phát triển (ZMP SDK) để truy cập các năng lực của thiết bị và các dịch vụ của Zalo [2].

3.1.1 Kiến trúc và mô hình hoạt động

Về mặt kiến trúc, một Zalo Mini App là một ứng dụng web (HTML, CSS, JavaScript) được nạp và thực thi bên trong một WebView do ứng dụng Zalo quản lý, thay vì được cài đặt như một ứng dụng gốc. Mô hình hoạt động có thể chia thành ba lớp: (1) *lớp giao diện* là ứng dụng web viết bằng React, chịu trách nhiệm hiển thị và xử lý tương tác của người dùng; (2) *lớp cầu nối* ZMP SDK — một lớp JavaScript trung gian chuyển các lời gọi API trong mã ứng dụng thành lệnh tới phần gốc (native) của Zalo và trả kết quả ngược lại; (3) *lớp năng lực nền tảng* do Zalo và hệ điều hành cung cấp, gồm máy ảnh, định vị, lưu trữ cục bộ, thông tin người dùng và các dịch vụ xã hội của Zalo. Nhờ cách tổ chức này, ứng dụng vừa tận dụng được hệ sinh thái web (thư viện React, công cụ đóng gói) vừa truy cập được năng lực thiết bị thông qua SDK, trong khi người dùng không phải cài đặt thêm bất kỳ phần mềm nào.

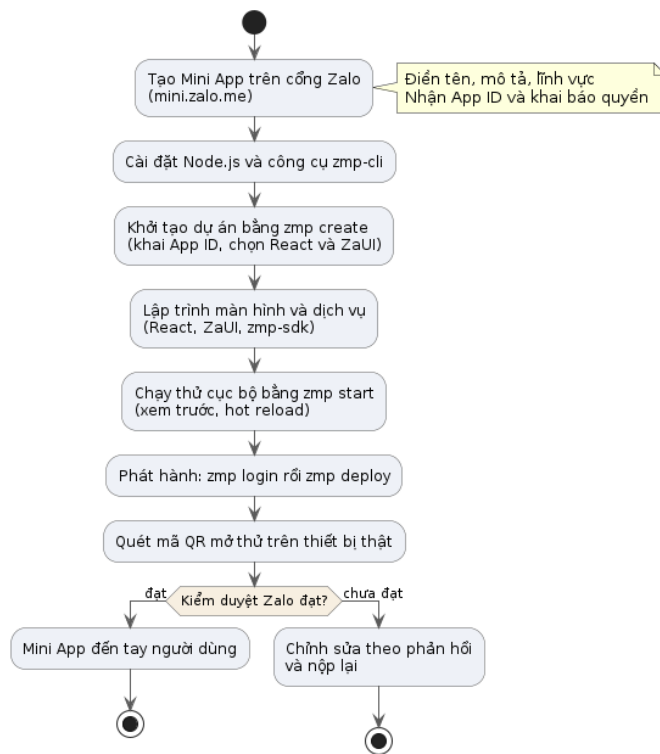
Hệ thống sử dụng các nhóm API chính sau của Zalo SDK: xác thực và lấy thông tin người dùng (`getUserInfo`, `getPhoneNumber`, `getAccessToken`); truy cập máy ảnh để chụp ảnh khuôn mặt và quét mã QR (`createCameraContext`, `scanQRCode`); truy cập vị trí (`getLocation`); và lưu trữ cục bộ trên thiết bị (`setItem`, `getItem`). Các API này được nạp theo nhu cầu từ gói `zmp-sdk`, kết hợp với bộ thành phần giao diện chuẩn của nền tảng (`zmp-ui`, hay `ZaUI`) để bảo đảm giao diện nhất quán với trải nghiệm của ứng dụng Zalo [8].

3.1.2 Quy trình xây dựng và phát hành ứng dụng

Việc phát triển một Mini App tuân theo quy trình do nền tảng quy định [8], có thể tóm lược thành năm bước từ đăng ký ứng dụng, khởi tạo mã nguồn, lập trình,

chạy thử cho đến phát hành lên hệ thống Zalo. Toàn bộ quy trình được minh họa trong Hình 3.1.

1. **Đăng ký và tạo Mini App trên cổng nền tảng.** Nhà phát triển đăng nhập cổng dành cho nhà phát triển của Zalo (`developers.zalo.me`) và bảng điều khiển Mini App tại `mini.zalo.me`, chọn chức năng *tạo Mini App mới* rồi khai báo các thông tin cơ bản: tên ứng dụng, mô tả và lĩnh vực (danh mục) hoạt động. Sau khi tạo, hệ thống cấp một **mã định danh ứng dụng (App ID)**; tại đây nhà phát triển cũng khai báo trước các quyền mà ứng dụng sẽ xin của người dùng (thông tin cá nhân, số điện thoại, vị trí) [2].
2. **Cài đặt công cụ và khởi tạo mã nguồn.** Trên máy phát triển, cài đặt Node.js và công cụ dòng lệnh `zmp-cli`. Lệnh `zmp create` khởi tạo một dự án mới: công cụ lần lượt hỏi App ID vừa được cấp, mã truy cập (access token), khung nền tảng (đề án chọn React) và mẫu khởi đầu (template), sau đó sinh ra bộ khung dự án sẵn sàng để phát triển.
3. **Tìm hiểu cấu trúc dự án.** Mã nguồn ứng dụng được đặt trong thư mục `src`, trong đó `pages` chứa các màn hình, `components` chứa các thành phần giao diện dùng lại, còn `services` và `hooks` xử lý nghiệp vụ và gọi dịch vụ. Tập `app-config.json` khai báo cấu hình toàn cục của Mini App như tên ứng dụng, biểu tượng, màu chủ đạo và danh sách trang. Đề án dùng Vite làm công cụ đóng gói, tích hợp với nền tảng qua `zmp-vite-plugin`; do vậy ứng dụng được chạy bằng `zmp start` thay vì gọi `vite` trực tiếp.
4. **Bắt đầu lập trình.** Mỗi màn hình được hiện thực dưới dạng một thành phần React trong `src/pages` và được khai báo tuyến đường (route) tương ứng; giao diện được dựng bằng React kết hợp bộ thành phần `ZaUI` (`zmp-ui`), còn các năng lực thiết bị và dịch vụ của Zalo được gọi qua các API của `zmp-sdk`. Lệnh `zmp start` khởi động một máy chủ phát triển cục bộ, cho phép xem trước ứng dụng trên trình duyệt và tự động nạp lại khi mã nguồn thay đổi (hot reload); trong giai đoạn này có thể bật chế độ dữ liệu giả lập để kiểm thử các luồng nghiệp vụ mà không phụ thuộc vào máy chủ thật.
5. **Phát hành.** Khi ứng dụng đã sẵn sàng, lệnh `zmp login` xác thực tài khoản nhà phát triển, còn `zmp deploy` đóng gói và tải bản dựng lên nền tảng. Hệ thống sinh ra một mã QR; quét mã này bằng ứng dụng Zalo sẽ mở Mini App ngay trên thiết bị thật, phục vụ việc kiểm thử trong môi trường gần với thực tế. Trước khi đến tay người dùng cuối, Mini App phải trải qua quy trình kiểm duyệt của Zalo nhằm bảo đảm tuân thủ chính sách của nền tảng [8].



Hình 3.1: Quy trình xây dựng và phát hành một Zalo Mini App

Các lệnh cụ thể cho từng bước cài đặt, chạy thử và triển khai được liệt kê chi tiết trong Danh sách mã nguồn A.3 và Danh sách mã nguồn A.4 ở phần phụ lục.

3.1.3 Lựa chọn nền tảng và mô hình quyền

Lý do lựa chọn. So với việc phát triển ứng dụng gốc (native) hay ứng dụng web lũy tiến (PWA), Zalo Mini App có lợi thế nổi bật là tiếp cận được lượng lớn người dùng Zalo tại Việt Nam mà không yêu cầu cài đặt, đồng thời cung cấp sẵn cơ chế xác thực danh tính. Bảng 3.1 so sánh ba phương án.

Bảng 3.1: So sánh Zalo Mini App với PWA và ứng dụng gốc

Tiêu chí	Zalo Mini App	PWA	Ứng dụng gốc
Cài đặt	Không cần	Không cần	Cần cài qua store
Tiếp cận người dùng	Rất rộng (qua Zalo)	Trung bình	Phụ thuộc lượt tải
Xác thực sẵn có	Có (tài khoản Zalo)	Không	Không
Truy cập API thiết bị	Qua ZMP SDK	Hạn chế	Đầy đủ
Chi phí phát hành	Thấp	Thấp	Cao

Mô hình quyền và vòng đời. Theo chính sách của nền tảng, Mini App không được yêu cầu cấp quyền ngay khi mở mà chỉ xin quyền khi người dùng chủ động thực hiện thao tác liên quan; các quyền (thông tin cá nhân, số điện thoại, vị trí)

được xin theo từng phạm vi riêng biệt. Định danh người dùng có thể lấy qua `getUserId` mà không cần quyền, thuận tiện cho việc khởi tạo phiên đăng nhập. Nền tảng cũng cung cấp các sự kiện vòng đời (tạm dừng, tiếp tục, thay đổi trạng thái mạng) để ứng dụng phản ứng phù hợp.

3.2 Bộ công nghệ phía giao diện

Phần giao diện của ứng dụng được xây dựng trên các công nghệ sau:

- **React 18** [9] – thư viện xây dựng giao diện theo mô hình thành phần (component), hỗ trợ cơ chế render đồng thời (concurrent) giúp giao diện mượt mà.
- **TypeScript** [10] – ngôn ngữ mở rộng của JavaScript với hệ thống kiểu tĩnh, giúp phát hiện sớm lỗi ngay khi viết mã và tăng độ tin cậy của hệ thống.
- **Jotai** – thư viện quản lý trạng thái theo mô hình “nguyên tử” (atomic), cho phép chia trạng thái ứng dụng thành các đơn vị nhỏ độc lập. So với Redux, Jotai có cú pháp gọn nhẹ và phù hợp với các ứng dụng vừa và nhỏ.
- **Tailwind CSS** – framework CSS theo hướng tiện ích (utility-first), kết hợp với SCSS để xây dựng giao diện nhất quán với bộ nhận diện của trường.
- **Vite** – công cụ đóng gói (bundler) tốc độ cao, được tích hợp với plugin riêng của Zalo Mini App để biên dịch và đóng gói ứng dụng.

3.3 Hệ sinh thái Firebase

Phần xử lý phía máy chủ được xây dựng trên nền tảng Firebase của Google, gồm các thành phần:

- **Firestore** [11] – cơ sở dữ liệu dạng tài liệu (NoSQL) có khả năng đồng bộ theo thời gian thực, phù hợp với việc cập nhật trạng thái phiên điểm danh trực tiếp tới thiết bị của giảng viên.
- **Cloud Functions** – môi trường thực thi mã phía máy chủ không cần quản lý hạ tầng (serverless), được dùng để xử lý các tác vụ nhạy cảm như ký và xác minh mã QR, phát hiện gian lận, tránh đặt logic quan trọng phía thiết bị người dùng.
- **Firebase Authentication** – dịch vụ xác thực, được dùng kết hợp với cơ chế cấp token tùy biến (Custom Token) để bắc cầu danh tính từ Zalo sang Firebase.
- **Firebase Hosting và Storage** – lần lượt phục vụ lưu trữ và phân phối trang quản trị web, và lưu trữ dữ liệu ảnh.

Lý do lựa chọn. Firebase cung cấp gói miễn phí (Spark) đủ cho phạm vi thử nghiệm, tích hợp sẵn khả năng đồng bộ thời gian thực và tự co giãn, giúp rút ngắn đáng kể thời gian phát triển so với việc tự xây dựng máy chủ.

Mô hình dữ liệu của Firestore. Firestore tổ chức dữ liệu thành các *collection* chứa các *document*; mỗi document gồm các trường và có thể chứa các *subcollection* lồng bên trong. Mô hình này linh hoạt, không yêu cầu lược đồ cứng như cơ sở dữ liệu quan hệ, nhưng đòi hỏi thiết kế cẩn thận để truy vấn hiệu quả. Việc kiểm soát truy cập được thực hiện bằng *quy tắc bảo mật* (Security Rules) — một ngôn ngữ khai báo quy định điều kiện đọc/ghi trên từng đường dẫn dữ liệu, áp dụng ngay tại tầng cơ sở dữ liệu. Bên cạnh đó, Cloud Functions hỗ trợ hai dạng chính: hàm gọi trực tiếp từ ứng dụng (callable) và hàm kích hoạt theo sự kiện (trigger) khi dữ liệu thay đổi; hệ thống chủ yếu dùng hàm callable cho các nghiệp vụ nhạy cảm và một số hàm theo lịch cho phân tích định kỳ.

3.4 HMAC-SHA256 và mã xác thực thông điệp

Mã xác thực thông điệp (Message Authentication Code – MAC) là một đoạn dữ liệu ngắn được sinh ra từ thông điệp và một khoá bí mật, dùng để xác minh tính toàn vẹn và tính xác thực của thông điệp. HMAC (Hash-based MAC) là một cấu trúc MAC dựa trên hàm băm mật mã, được chuẩn hoá trong RFC 2104 [12].

Hàm băm mật mã. Một hàm băm mật mã H ánh xạ dữ liệu có độ dài bất kỳ thành một chuỗi bit độ dài cố định và cần thoả mãn ba tính chất an toàn: kháng tiền ảnh (khó tìm m khi biết $H(m)$), kháng tiền ảnh thứ hai (khó tìm $m' \neq m$ sao cho $H(m') = H(m)$) và kháng va chạm (khó tìm hai thông điệp bất kỳ có cùng giá trị băm). Hàm băm được sử dụng trong đề án là SHA-256 thuộc họ SHA-2, cho đầu ra 256 bit và được chuẩn hoá trong FIPS 180-4 [13].

Các hàm băm họ SHA-2 được xây dựng theo lối băm lặp khối (iterated construction). Một hệ quả của lối xây dựng này là điểm yếu *tấn công mở rộng độ dài* (length-extension): nếu chỉ tính $H(K \parallel m)$ một cách trực tiếp, kẻ tấn công biết giá trị băm và độ dài khoá có thể suy ra giá trị băm cho một thông điệp mở rộng mà không cần biết khoá. HMAC khắc phục điều này bằng cách lồng hàm băm hai lần với hai lớp đệm khoá khác nhau.

Với hàm băm H , khoá bí mật K và thông điệp m , giá trị HMAC được định nghĩa như sau:

$$\text{HMAC}(K, m) = H((K' \oplus \text{opad}) \parallel H((K' \oplus \text{ipad}) \parallel m)) \quad (3.1)$$

trong đó K' là khoá K được chuẩn hoá về độ dài khối của hàm băm; *opad* và *ipad* là hai hằng số đệm; $\oplus$ là phép XOR theo bit; và $\parallel$ là phép nối chuỗi. Trong đề án, hàm băm được sử dụng là **SHA-256** [13] do tính kháng va chạm cao và được chuẩn hoá rộng rãi.

Ứng dụng trong mã QR động. Hệ thống tạo nội dung mã QR gồm các trường định danh phiên, mốc thời gian và một giá trị ngẫu nhiên, sau đó ký toàn bộ bằng HMAC-SHA256 với khoá bí mật chỉ được biết phía máy chủ. Nhờ tính chất của HMAC, một bên không nắm giữ khoá bí mật không thể tạo ra mã QR hợp lệ; kết hợp với việc mốc thời gian thay đổi mỗi 30 giây, cơ chế này chống lại việc chụp và phát lại mã QR. Chi tiết thuật toán được trình bày trong Chương 4.

Tính an toàn. Cấu trúc lồng hai lần hàm băm của HMAC giúp nó kháng được tấn công mở rộng độ dài (length-extension) vốn ảnh hưởng tới cách dùng hàm băm một cách trực tiếp. Với SHA-256 — hàm băm cho đầu ra 256 bit, có độ kháng va chạm và kháng tiền ảnh cao — việc dò tìm khoá bí mật bằng vét cạn là bất khả thi trên thực tế. Do đó, kể cả khi quan sát được nhiều mã QR hợp lệ, kẻ tấn công vẫn không thể suy ra khoá bí mật để giả mạo một mã mới. Về mặt lý thuyết, HMAC đã được chứng minh là một hàm giả ngẫu nhiên (pseudorandom function – PRF) và do đó là một mã xác thực thông điệp an toàn, với điều kiện hàm nén bên dưới là một PRF [14].

Chống phát lại. Mỗi mã QR mang theo một mốc thời gian và một giá trị ngẫu nhiên dùng một lần (nonce). Phía máy chủ chỉ chấp nhận mã trong cửa sổ thời gian ngắn (90 giây) và từ chối các nonce đã xuất hiện, nhờ đó một mã bị chụp lại sẽ nhanh chóng hết hiệu lực và không thể tái sử dụng cho lần điểm danh khác.

3.5 Nhận diện khuôn mặt và FaceNet

Bài toán xác minh khuôn mặt (face verification) là xác định hai ảnh khuôn mặt có thuộc về cùng một người hay không, khác với bài toán nhận dạng (identification) là tìm danh tính trong một tập lớn. Hệ thống điểm danh sử dụng bài toán xác minh: so khớp khuôn mặt thu được tại thời điểm điểm danh với khuôn mặt đã đăng ký của sinh viên.

Phương pháp hiện đại dựa trên mạng nơ-ron tích chập (CNN) [15], [16] để trích xuất một véc-tơ đặc trưng (embedding) có số chiều cố định từ ảnh khuôn mặt. Tiếp nối các mô hình học sâu cho khuôn mặt như DeepFace [17], mô hình tiêu biểu là FaceNet sử dụng hàm mất mát bộ ba (triplet loss) để học không gian đặc trưng sao cho khoảng cách giữa các ảnh cùng người là nhỏ và giữa các ảnh khác người là lớn [7]. Việc so khớp khi đó quy về so sánh khoảng cách giữa hai véc-tơ đặc trưng với một ngưỡng cho trước.

Cấu trúc trích đặc trưng. Mạng nơ-ron tích chập trích đặc trưng theo tầng: các tầng tích chập (convolution) học các bộ lọc phát hiện đặc trưng cục bộ như cạnh, góc và kết cấu; các tầng gộp (pooling) giảm kích thước không gian và tăng tính bất biến với dịch chuyển nhỏ; còn các tầng phía sau tổng hợp lại thành véc-tơ

đặc trưng. Các kiến trúc rất sâu với kết nối phần dư (residual connection) cho phép huấn luyện ổn định và nâng cao chất lượng đặc trưng học được [16].

Hàm mất mát bộ ba. FaceNet huấn luyện mạng sao cho các ảnh của cùng một người nằm gần nhau còn ảnh của những người khác nhau nằm xa nhau trong không gian đặc trưng. Với mỗi bộ ba gồm ảnh neo x^a , ảnh cùng người x^p và ảnh khác người x^n , hàm mất mát cần tối thiểu hoá được biểu diễn trong Phương trình 3.2:

$$\mathcal{L} = \sum_{i=1}^N \left[\|f(x_i^a) - f(x_i^p)\|_2^2 - \|f(x_i^a) - f(x_i^n)\|_2^2 + \alpha \right]_+ \quad (3.2)$$

trong đó $f(\cdot)$ là véc-tơ đặc trưng (được chuẩn hoá về chuẩn đơn vị), α là biên (margin) tối thiểu giữa cặp cùng người và cặp khác người, và $[z]_+ = \max(z, 0)$. Việc tối ưu hàm mất mát này tạo ra không gian đặc trưng mà ở đó khoảng cách Euclid phản ánh mức độ giống nhau của hai khuôn mặt [7].

Trong đồ án, quá trình xác minh khuôn mặt được thực hiện phía thiết bị người dùng nhằm bảo vệ quyền riêng tư của dữ liệu sinh trắc học. Hạn chế của cách tiếp cận này là chưa có cơ chế phát hiện sự sống (liveness detection) ở mức nâng cao để chống giả mạo bằng ảnh tĩnh; đây là một đánh đổi đã được ghi nhận và trình bày trong phần hạn chế ở Chương 6.

Quy trình xử lý. Việc xác minh khuôn mặt trải qua bốn bước: (1) phát hiện khuôn mặt trong khung hình; (2) căn chỉnh theo các điểm mốc (landmark) trên khuôn mặt; (3) trích véc-tơ đặc trưng 128 chiều bằng mạng nơ-ron; và (4) so sánh khoảng cách Euclid giữa véc-tơ thu được với véc-tơ đã đăng ký. Hai khuôn mặt được xem là của cùng một người nếu khoảng cách nhỏ hơn một ngưỡng cho trước (trong đồ án là 0,6).

Đồ án sử dụng thư viện nhận diện khuôn mặt face-api.js [18] chạy trực tiếp trên trình duyệt, với mô hình phát hiện gọn nhẹ để phù hợp với tài nguyên của thiết bị di động. Vì toàn bộ quá trình diễn ra trên thiết bị, hệ thống chỉ lưu véc-tơ đặc trưng — vốn không thể phục hồi ngược lại thành ảnh — thay cho ảnh khuôn mặt gốc, qua đó giảm thiểu rủi ro lộ lọt dữ liệu sinh trắc học.

3.6 Mã QR và ứng dụng trong điểm danh

Mã QR (Quick Response code) [19] là một dạng mã vạch hai chiều có khả năng lưu trữ lượng dữ liệu lớn hơn nhiều so với mã vạch một chiều, đồng thời cho phép quét nhanh từ nhiều góc độ. Một đặc điểm quan trọng của mã QR là cơ chế **sửa lỗi** (error correction) dựa trên mã Reed–Solomon, cho phép khôi phục dữ liệu ngay cả khi một phần mã bị che khuất hoặc hư hỏng ở một mức độ nhất định.

Cấu trúc và khả năng sửa lỗi. Một mã QR gồm các thành phần định vị — ba ô tìm kiếm (finder pattern) ở ba góc, cùng các mẫu căn chỉnh (alignment) và định thời (timing) — bên cạnh vùng thông tin định dạng/phiên bản và vùng dữ liệu. Chuẩn ISO/IEC 18004 định nghĩa bốn mức sửa lỗi L, M, Q và H, lần lượt cho phép khôi phục khoảng 7%, 15%, 25% và 30% số từ mã bị hỏng [19]. Mức sửa lỗi càng cao thì khả năng quét trong điều kiện che khuất hay bẩn càng tốt, nhưng dung lượng dữ liệu khả dụng càng giảm. Ở phiên bản lớn nhất (phiên bản 40), một mã QR có thể chứa tối đa khoảng 2953 byte dữ liệu nhị phân. Nội dung mã QR của hệ thống — một chuỗi JSON đã ký HMAC — chỉ dài khoảng vài trăm byte nên luôn nằm trong giới hạn này, kể cả khi chọn mức sửa lỗi cao để tăng độ tin cậy khi quét.

Trong hệ thống điểm danh, mã QR được dùng làm phương tiện truyền tải gọn nhẹ cho hai mục đích: truyền nội dung đã ký HMAC từ màn hình giảng viên tới thiết bị sinh viên, và trao đổi thông tin xác minh giữa các sinh viên trong bước ngang hàng. Ưu điểm của mã QR là không đòi hỏi kết nối trực tiếp giữa hai thiết bị — chỉ cần một bên hiển thị và một bên dùng máy ảnh để quét — nên rất phù hợp với môi trường lớp học. Tuy nhiên, do mã QR tính dễ bị chụp lại và chia sẻ, đồ án kết hợp mã QR với chữ ký HMAC và cơ chế xoay mã theo thời gian tương tự mật khẩu dùng một lần theo thời gian (TOTP) [20] để khắc phục nhược điểm này (mục 3.4).

Kết chương

Chương này đã trình bày các công nghệ nền tảng (Zalo Mini App, React, Firebase) cùng các kiến thức lý thuyết cốt lõi (HMAC-SHA256, nhận diện khuôn mặt, mã QR) và lý do lựa chọn chúng. Các công nghệ này là cơ sở để thiết kế và triển khai hệ thống được trình bày trong chương tiếp theo.

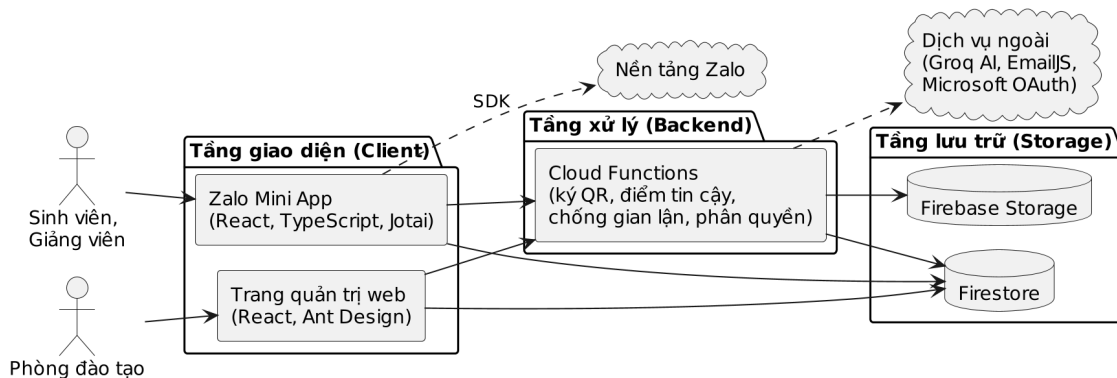
CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

Đây là chương trọng tâm của đồ án. Chương trình bày thiết kế tổng thể và chi tiết của hệ thống (kiến trúc, cơ sở dữ liệu, luồng xác thực, các thuật toán cốt lõi, quy trình điểm danh và chống gian lận), tiếp đó là quá trình triển khai thành sản phẩm thực tế, và cuối cùng là kết quả đánh giá trên các tiêu chí chức năng, bảo mật và hiệu năng.

4.1 Thiết kế kiến trúc

Hệ thống được tổ chức theo mô hình ba tầng (three-tier), gồm tầng giao diện phía người dùng, tầng xử lý nghiệp vụ và tầng lưu trữ dữ liệu, như minh họa trong Hình 4.1.

- **Tầng giao diện (Client).** Bao gồm *Zalo Mini App* phục vụ sinh viên cùng giảng viên và *trang quản trị web* phục vụ phòng đào tạo. Tầng này chịu trách nhiệm hiển thị, thu nhận thao tác người dùng, chụp ảnh khuôn mặt và quét mã QR.
- **Tầng xử lý (Backend).** Gồm các hàm Cloud Functions xử lý các nghiệp vụ nhạy cảm: ký và xác minh mã QR, tính điểm tin cậy, phát hiện gian lận, xác thực và phân quyền. Việc đặt các logic quan trọng ở tầng máy chủ giúp tránh để lộ khoá bí mật hay bị can thiệp từ phía thiết bị người dùng.
- **Tầng lưu trữ (Storage).** Gồm cơ sở dữ liệu Firestore lưu dữ liệu nghiệp vụ và đồng bộ theo thời gian thực, cùng Firebase Storage lưu trữ dữ liệu ảnh.



Hình 4.1: Kiến trúc tổng thể ba tầng của hệ thống

4.2 Thiết kế chi tiết

Phần này trình bày thiết kế chi tiết của các thành phần cốt lõi trong hệ thống.

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

4.2.1 Thiết kế cơ sở dữ liệu Firestore

Khác với cơ sở dữ liệu quan hệ, Firestore lưu dữ liệu theo mô hình tài liệu (document): dữ liệu được tổ chức thành các *collection*, mỗi collection chứa nhiều *document*. Hệ thống sử dụng các collection chính được liệt kê trong Bảng 4.1.

Bảng 4.1: Các collection chính của cơ sở dữ liệu

Collection	Mô tả
users	Hồ sơ người dùng (sinh viên, giảng viên, quản trị viên)
classes	Thông tin lớp học phần, lịch học, danh sách sinh viên
sessions	Phiên điểm danh, kèm khoá bí mật HMAC và cấu hình
attendance	Bản ghi điểm danh của từng sinh viên trong một phiên
face_registrations	Dữ liệu khuôn mặt đã đăng ký của sinh viên
pairing_tokens	Mã ghép nối cho tính năng Cổng máy chiếu
fraud_reports	Báo cáo phát hiện gian lận theo phiên
absence_requests	Đơn xin nghỉ của sinh viên

Thiết kế chi tiết của hai collection quan trọng nhất — *sessions* và *attendance* — được trình bày trong Bảng 4.2 và Bảng 4.3. Sơ đồ thực thể — liên kết tổng thể được trình bày trong Hình 4.2.

Bảng 4.2: Cấu trúc collection *sessions*

Trường	Kiểu	Ý nghĩa
classId	string	Mã lớp học phần
status	string	Trạng thái: <i>active</i> / <i>ended</i>
hmacSecret	string	Khoá bí mật để ký mã QR
qrRefreshInterval	number	Chu kỳ làm mới mã QR (giây)
faceRequired	boolean	Có yêu cầu xác minh khuôn mặt không
peerRequired	boolean	Có yêu cầu xác minh ngang hàng không
geoFenceRadius	number	Bán kính hàng rào địa lý (mét)
startedAt	number	Thời điểm bắt đầu phiên

Bảng 4.3: Cấu trúc collection *attendance*

Trường	Kiểu	Ý nghĩa
sessionId	string	Mã phiên điểm danh
studentId	string	Mã sinh viên
peerVerifications	array	Danh sách xác minh ngang hàng
peerCount	number	Số lượt xác minh ngang hàng
trustPolicy	string	Điểm tin cậy: <i>present</i> / <i>review</i> / <i>absent</i>
faceVerification	object	Kết quả xác minh khuôn mặt
location	object	Toạ độ GPS lúc điểm danh

Ngoài hai collection trên, cấu trúc của một số collection quan trọng khác được

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

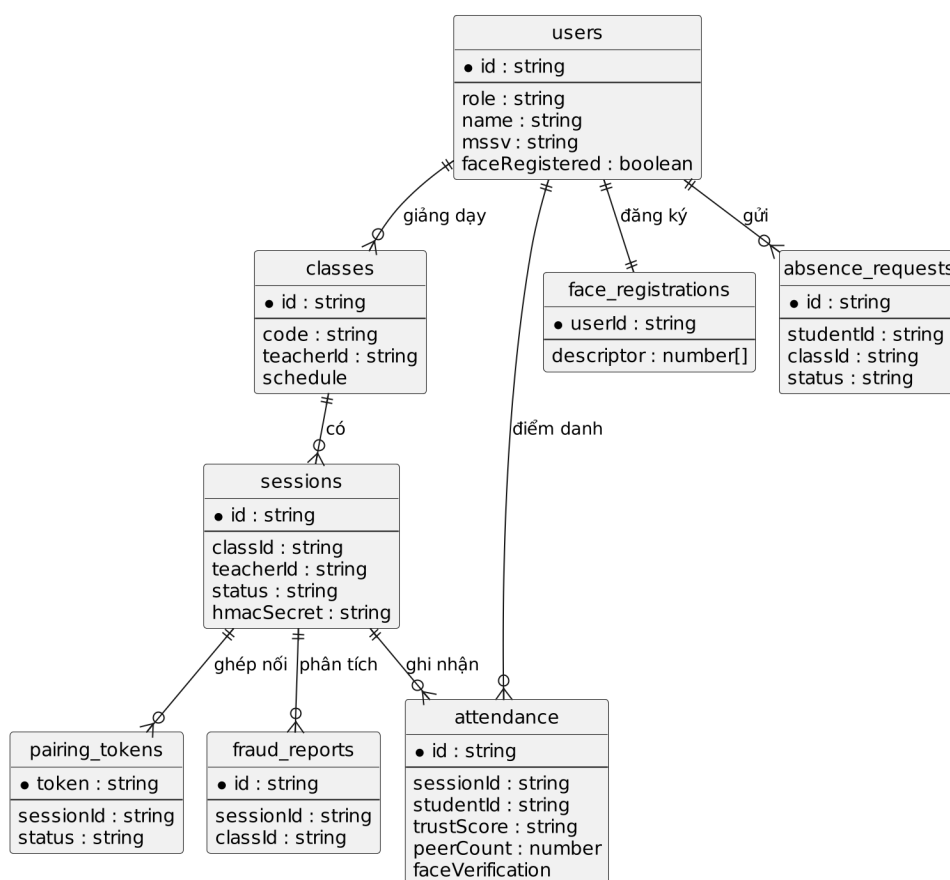
trình bày trong Bảng 4.4 và Bảng 4.5.

Bảng 4.4: Cấu trúc collection users

Trường	Kiểu	Ý nghĩa
id	string	Định danh người dùng (theo Zalo)
role	string	Vai trò: student/teacher/admin
name	string	Họ và tên
mssv	string	Mã số sinh viên (nếu là sinh viên)
faceRegistered	boolean	Đã đăng ký khuôn mặt hay chưa
hustVerified	boolean	Đã xác minh email do trường cấp

Bảng 4.5: Cấu trúc collection classes

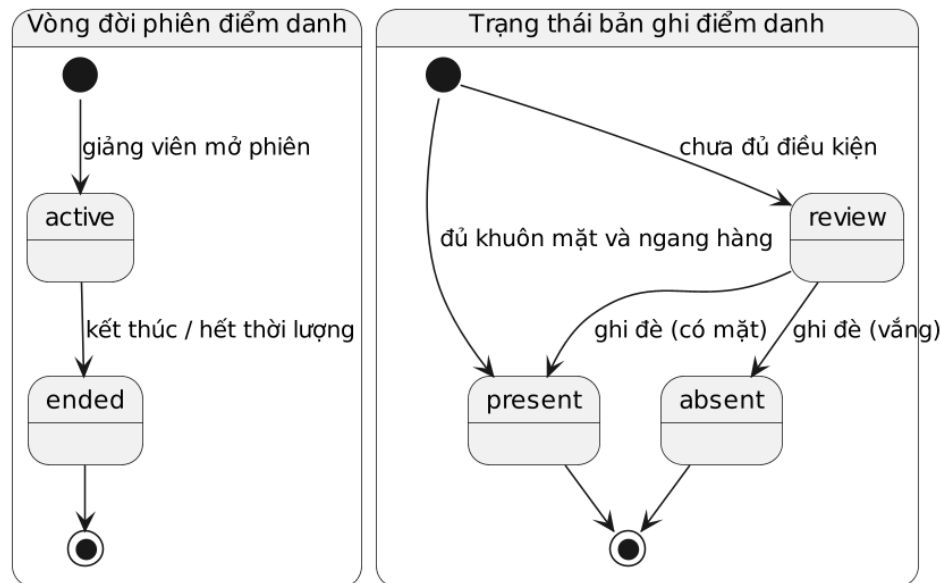
Trường	Kiểu	Ý nghĩa
id	string	Định danh lớp học phần
code	string	Mã lớp để sinh viên tham gia
teacherId	string	Định danh giảng viên phụ trách
studentIds	array	Danh sách sinh viên trong lớp
schedule	object	Lịch học (thứ, giờ bắt đầu, giờ kết thúc)



Hình 4.2: Sơ đồ thực thể — liên kết của cơ sở dữ liệu

Vòng đời của phiên điểm danh và trạng thái của bản ghi điểm danh được mô tả

bằng lược đồ trạng thái trong Hình 4.3.



Hình 4.3: Lược đồ trạng thái của phiên và bản ghi điểm danh

4.2.2 Thiết kế luồng xác thực và phân quyền

Luồng xác thực dựa trên việc đăng nhập bằng tài khoản Zalo để lấy danh tính cơ bản, sau đó sinh Custom Token của Firebase để thống nhất danh tính người dùng trên toàn hệ thống.

Việc phân quyền được thực thi ở tầng cơ sở dữ liệu bằng quy tắc bảo mật (Security Rules) của Firestore. Một nguyên tắc quan trọng là **ngăn người dùng tự nâng quyền**: tài khoản tạo từ phía thiết bị chỉ được phép mang vai trò `student`, còn vai trò `teacher` và `admin` chỉ được gán bởi Cloud Function. Đoạn quy tắc minh hoạ cho collection `users` như sau:

```
1 match /users/{userId} {
2   allow read:    if true;
3   allow create:  if newDocSafeRole(); // role chỉ được là "
      student"
4   allow update:  if notChangingRole(); // không được tự đổi role
5   allow delete:  if false;
6 }
```

Danh sách mã nguồn 4.1: Quy tắc bảo mật cho collection `users`

Tương tự, collection `attendance` bị khoá ghi từ phía thiết bị — mọi thao tác ghi chỉ được thực hiện qua Cloud Function, như Danh sách mã nguồn 4.2.

```
1 match /attendance/{id} {
2   allow read:    if true;
3   allow create:  if false; // chỉ tạo qua Cloud Function
```

```

4   allow update: if false;
5   allow delete: if false;
6 }

```

Danh sách mã nguồn 4.2: Quy tắc bảo mật cho collection attendance

Ma trận phân quyền tổng quát theo vai trò được tóm tắt trong Bảng 4.6.

Bảng 4.6: Ma trận phân quyền theo vai trò

Thao tác	Sinh viên	Giảng viên	Quản trị
Điểm danh	Có	—	—
Tạo/quản lý phiên điểm danh	—	Có	—
Duyệt, điểm danh thủ công	—	Có	—
Quản lý người dùng, lớp	—	—	Có
Duyệt đơn xin nghỉ	—	—	Có

4.2.3 Thuật toán mã QR HMAC xoay 30 giây

Để chống việc chụp màn hình và chia sẻ lại mã QR, hệ thống sinh mã QR động được ký bằng HMAC-SHA256 (xem công thức (3.1)) và làm mới sau mỗi 30 giây. Nội dung được ký là chuỗi ghép từ năm trường: loại mã, mã phiên, mã người dùng, mốc thời gian và một giá trị ngẫu nhiên (nonce). Thuật toán sinh mã được trình bày trong Thuật toán 1.

Thuật toán 1: Sinh mã QR động của giảng viên

Input: Loại mã *type*, mã phiên *sid*, mã người dùng *uid*, khoá bí mật *K*

Output: Chuỗi mã QR đã ký

ts ← mốc thời gian hiện tại;

nonce ← chuỗi ngẫu nhiên 16 byte;

msg ← *type* : *sid* : *uid* : *ts* : *nonce*;

sig ← HMAC-SHA256(*msg*, *K*);

return JSON(*type*, *sid*, *uid*, *ts*, *nonce*, *sig*);

Đoạn mã rút gọn cho việc sinh mã QR đã ký bằng HMAC được trình bày trong Danh sách mã nguồn 4.3.

```

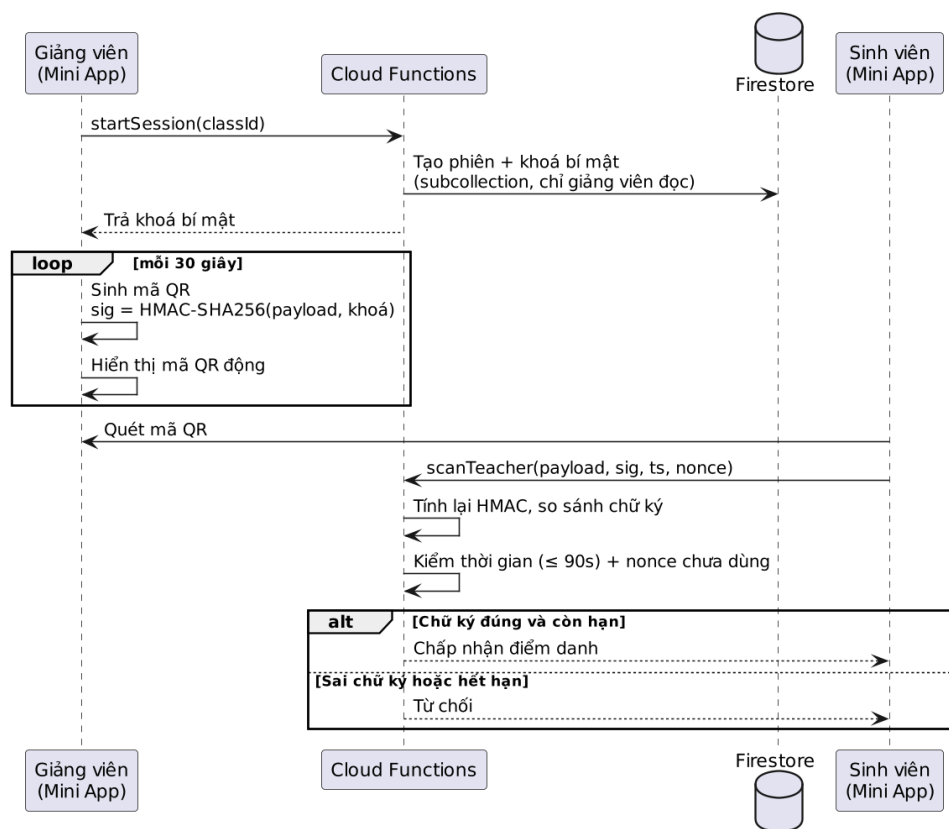
1 function buildQR(type, sessionId, userId, secret) {
2   const ts = Date.now();
3   const nonce = randomHex(16);
4   const msg = [type, sessionId, userId, ts, nonce].join(":");
5   const sig = HmacSHA256(msg, secret).toString();
6   return JSON.stringify({ type, sessionId, userId, ts, nonce, sig
7     });
}

```

Danh sách mã nguồn 4.3: Sinh mã QR đã ký HMAC-SHA256

Phía sinh viên (hoặc máy chủ) xác minh mã bằng cách tính lại chữ ký từ cùng nội dung và khoá bí mật rồi so sánh với chữ ký kèm theo; mã chỉ hợp lệ nếu chữ ký trùng khớp và mốc thời gian còn trong khoảng dung sai 90 giây. Khoảng dung sai 90 giây (gấp ba chu kỳ làm mới) nhằm dung hoà sai lệch đồng hồ giữa các thiết bị mà vẫn giới hạn thời gian sống của mã. Nhờ đó, ngay cả khi mã QR bị chụp lại, nó cũng nhanh chóng hết hạn và không thể dùng cho buổi học khác.

Toàn bộ quá trình khởi tạo khoá bí mật, sinh mã QR động và xác minh phía máy chủ được minh hoạ trong Hình 4.4.



Hình 4.4: Lược đồ tuần tự sinh và xác minh mã QR HMAC

4.2.4 Thiết kế giao diện và bộ nhận diện

Giao diện ứng dụng tuân theo bộ nhận diện của Đại học Bách Khoa Hà Nội, với màu chủ đạo là đỏ HUST (mã màu #be1d2c). Hệ thống xây dựng một bộ thành phần giao diện dùng chung nhằm bảo đảm tính nhất quán, tiêu biểu gồm: thẻ thống kê, vòng tròn điểm tin cậy (score ring), thanh tiến trình, hộp thoại dạng trượt từ dưới lên, và trình quét mã QR nhúng trực tiếp. Toàn bộ giao diện được tối ưu cho màn hình điện thoại với thao tác tối giản, phù hợp với kỳ vọng về tốc độ của sinh

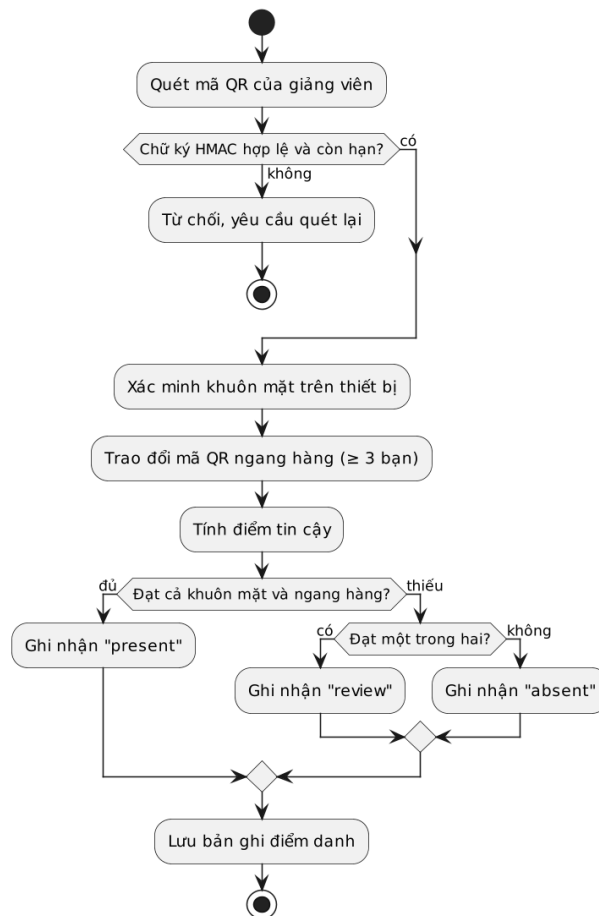
viên.

4.2.5 Luồng điểm danh bốn bước cho sinh viên

Quy trình điểm danh của sinh viên gồm bốn bước tuần tự:

1. **Quét mã QR của giảng viên.** Sinh viên dùng máy ảnh quét mã QR động đang hiển thị; hệ thống xác minh chữ ký HMAC và mốc thời gian.
2. **Xác minh khuôn mặt.** Ứng dụng tự động chụp và so khớp khuôn mặt với ảnh đã đăng ký; kết quả đạt nếu độ tin cậy không nhỏ hơn ngưỡng 0,7.
3. **Xác minh ngang hàng.** Sinh viên hiển thị mã QR cá nhân và tự quét mã của các bạn xung quanh; chỉ lượt do chính sinh viên quét mới được tính, yêu cầu tối thiểu một lượt xác minh.
4. **Hoàn tất.** Hệ thống tổng hợp kết quả và tính điểm tin cậy.

Quy trình điểm danh tổng quát cùng các điểm rẽ nhánh quyết định được minh hoạ dưới dạng lược đồ hoạt động trong Hình 4.5.



Hình 4.5: Lược đồ hoạt động của quy trình điểm danh

Điểm tin cậy (trust policy) được tính theo quy tắc: đạt present nếu vượt qua

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

cả điều kiện khuôn mặt và điều kiện ngang hàng; *review* (cần xem xét) nếu chỉ đạt một trong hai; và *absent* nếu không đạt cả hai. Quy tắc này cho phép giảng viên tập trung kiểm tra thủ công các trường hợp ở trạng thái *review*. Quy tắc tính điểm tin cậy được trình bày hình thức trong Thuật toán 2.

Thuật toán 2: Tính điểm tin cậy của một lượt điểm danh

Input: Cờ yêu cầu khuôn mặt *faceReq*, cờ yêu cầu ngang hàng *peerReq*, kết quả khuôn mặt *face*, số lượt ngang hàng *peerCount*

Output: Điểm tin cậy thuộc {*present*, *review*, *absent*}

$facePass \leftarrow (\neg faceReq) \vee face.matched;$

$peerPass \leftarrow (\neg peerReq) \vee (peerCount \geq 1);$

if *facePass* **và** *peerPass* **then**

return *present*;

else

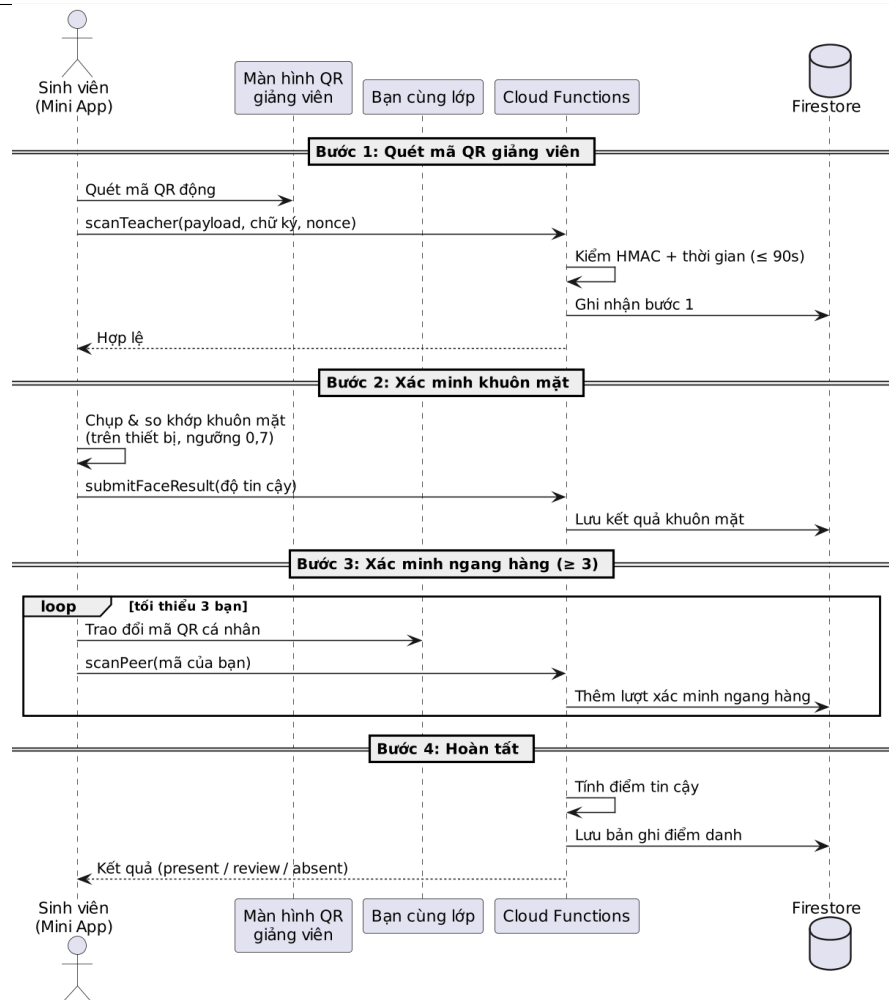
if *facePass* **hoặc** *peerPass* **then**

return *review*;

else

return *absent*;

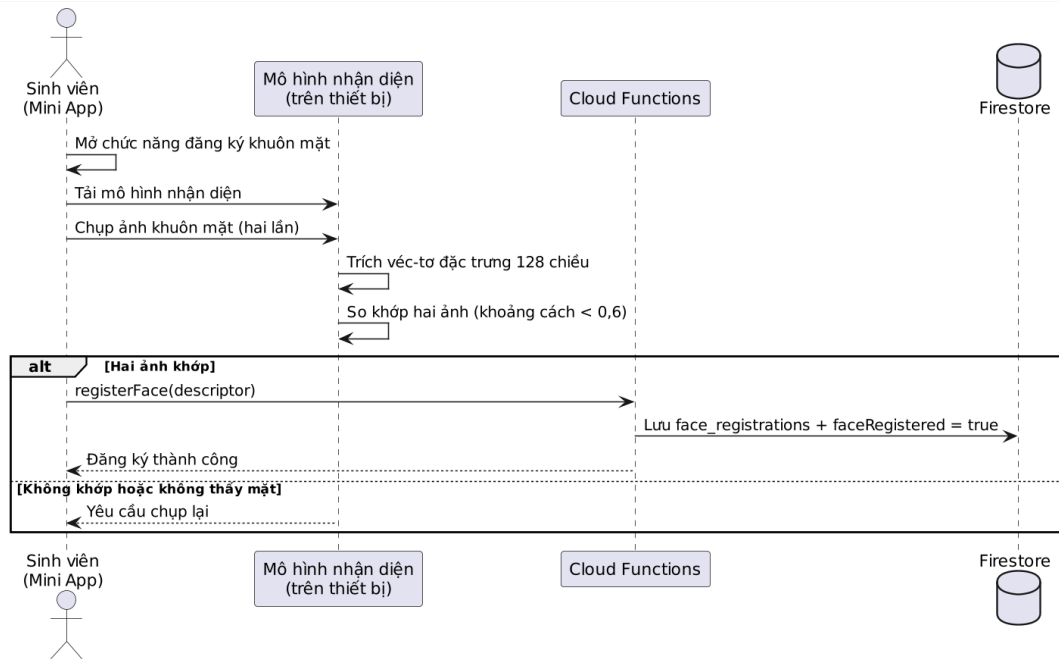
Toàn bộ trình tự tương tác của quy trình điểm danh bốn bước được minh họa trong Hình 4.6.



Hình 4.6: Lược đồ tuần tự quy trình điểm danh bốn bước

Quy trình đăng ký khuôn mặt — điều kiện tiên quyết cho bước xác minh khi điểm danh — được minh hoạ trong Hình 4.7.

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG



Hình 4.7: Lược đồ tuần tự đăng ký khuôn mặt

4.2.6 Hệ thống chống gian lận nhiều lớp

Hệ thống áp dụng nguyên lý phòng thủ theo chiều sâu với nhiều lớp xác minh bổ trợ: mã QR động (chống chia sẻ mã), xác minh khuôn mặt (chống điểm danh hộ), xác minh ngang hàng (chống điểm danh từ xa) và kiểm tra vị trí GPS (chống điểm danh ngoài lớp). Bổ sung cho các lớp này, một hàm phân tích chạy phía máy chủ rà soát các mẫu hành vi đáng ngờ và lập báo cáo gian lận. Các loại hành vi đáng ngờ được hệ thống phát hiện được tổng hợp trong Bảng 4.7.

Bảng 4.7: Phân loại các hành vi đáng ngờ

Loại	Mô tả
<code>always_same_peers</code>	Luôn xác minh ngang hàng với cùng một nhóm bạn
<code>rapid_verification</code>	Tốc độ xác minh nhanh bất thường
<code>low_peer_count</code>	Số lượt xác minh ngang hàng quá thấp
<code>face_mismatch</code>	Khuôn mặt không khớp
<code>ai_detected</code>	Mẫu bất thường do mô hình phân tích phát hiện

Thuật toán phân tích phát hiện gian lận theo phiên được trình bày trong Thuật toán 3.

Thuật toán 3: Phân tích phát hiện gian lận theo phiên

Input: Tập bản ghi điểm danh A của lớp

Output: Danh sách mẫu hành vi đáng ngờ S

$S \leftarrow \emptyset$;

foreach *sinh viên* s trong A **do**

if *tỷ lệ xác minh cùng một nhóm bạn* $\geq 80\%$ **then** thêm

always_same_peers;

if *khoảng cách giữa hai lượt xác minh* < 30 *giây* **then** thêm

rapid_verification;

if *số lượt ngang hàng* ≤ 1 *ở quá nửa số phiên* **then** thêm

low_peer_count;

if *khuôn mặt không khớp hoặc độ tin cậy* $< 0,3$ **then** thêm

face_mismatch;

return S ;

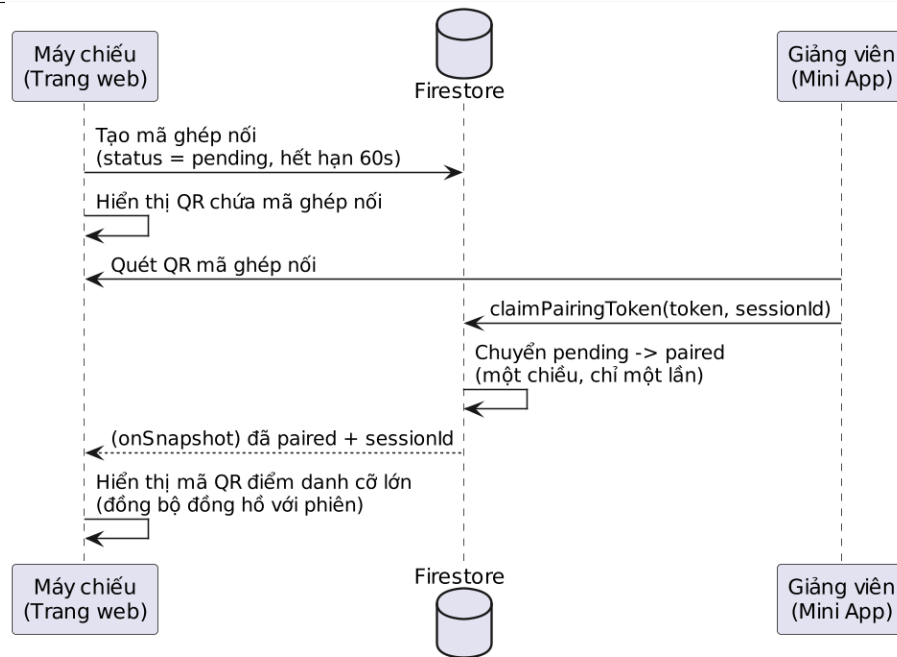
Kiểm tra vị trí GPS (hàng rào địa lý). Khi giảng viên mở phiên điểm danh, ứng dụng ghi lại toạ độ GPS của thiết bị giảng viên làm tâm khu vực lớp học cùng bán kính cho phép (mặc định 200 m). Khi sinh viên điểm danh, thiết bị lấy toạ độ hiện tại và tính khoảng cách tới tâm bằng công thức Haversine; nếu vượt quá bán kính, lượt điểm danh bị từ chối. Trường hợp sinh viên tắt định vị hoặc từ chối quyền, hệ thống không chặn cứng mà đánh dấu bản ghi “cần xem xét” để giảng viên duyệt. Việc kiểm tra được thực hiện đồng thời ở thiết bị và trên máy chủ (Cloud Function tính lại khoảng cách), nên không thể vượt qua bằng cách can thiệp phía máy khách.

4.2.7 Tính năng Cổng máy chiếu (Teacher Display)

Mã QR hiển thị trên màn hình điện thoại của giảng viên thường quá nhỏ đối với các lớp học đông. Để khắc phục, hệ thống thiết kế tính năng *Cổng máy chiếu*: trang quản trị web mở trên máy chiếu sẽ sinh một mã ghép nối (pairing token) ngẫu nhiên dài 128 bit, có thời hạn 60 giây. Giảng viên dùng Mini App quét mã ghép nối này để liên kết phiên điểm danh với màn hình máy chiếu; sau đó mã QR động cỡ lớn sẽ được hiển thị trên máy chiếu.

Trạng thái của mã ghép nối chỉ chuyển một chiều từ *pending* sang *paired* và không thể quay lại hay bị ghép nối hai lần, nhằm chống tấn công chiếm quyền hiển thị. Mã QR trên máy chiếu và trên Mini App được đồng bộ theo cùng một đồng hồ để bảo đảm tính nhất quán khi làm mới. Trình tự ghép nối được minh hoạ trong Hình 4.8.

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG



Hình 4.8: Lược đồ tuần tự ghép nối Cổng máy chiếu

Hình 4.9 thể hiện giao diện trang Cổng máy chiếu khi chạy trên trình duyệt.



Hình 4.9: Giao diện Cổng máy chiếu trên trình duyệt

4.3 Xây dựng ứng dụng

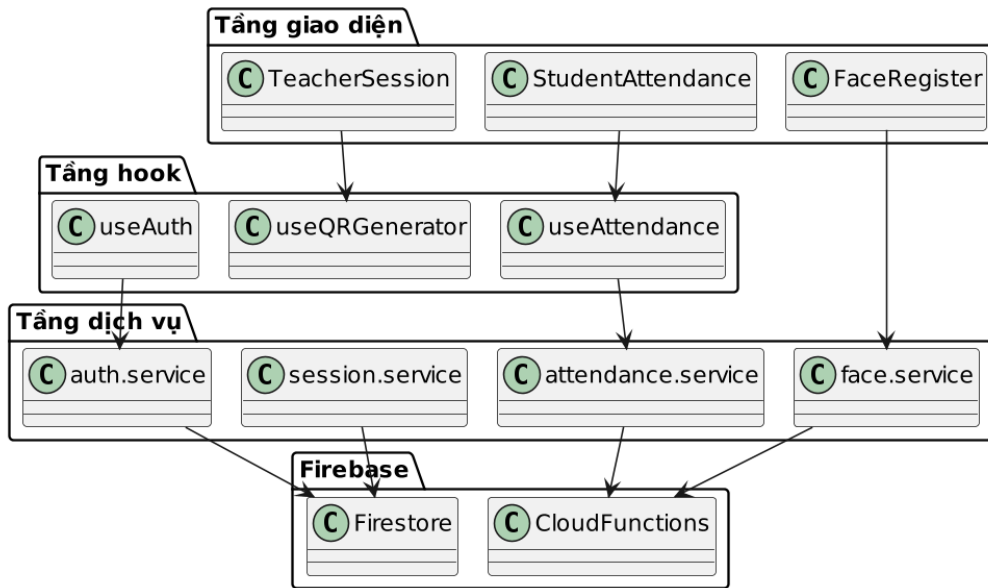
Phần này trình bày quá trình hiện thực hoá hệ thống thành ba thành phần: Mini App, trang quản trị và các hàm xử lý phía máy chủ.

4.3.1 Triển khai Mini App

Phần Mini App được hiện thực bằng React và TypeScript với quy mô khoảng 15.900 dòng mã, tổ chức thành 21 trang giao diện, 27 thành phần dùng chung, 10 hook tùy biến và 16 lớp dịch vụ (service) đảm nhiệm việc giao tiếp với Firestore

và Cloud Functions.

Mối quan hệ phân lớp giữa các thành phần giao diện, hook, dịch vụ và Firebase được minh hoạ trong Hình 4.10.



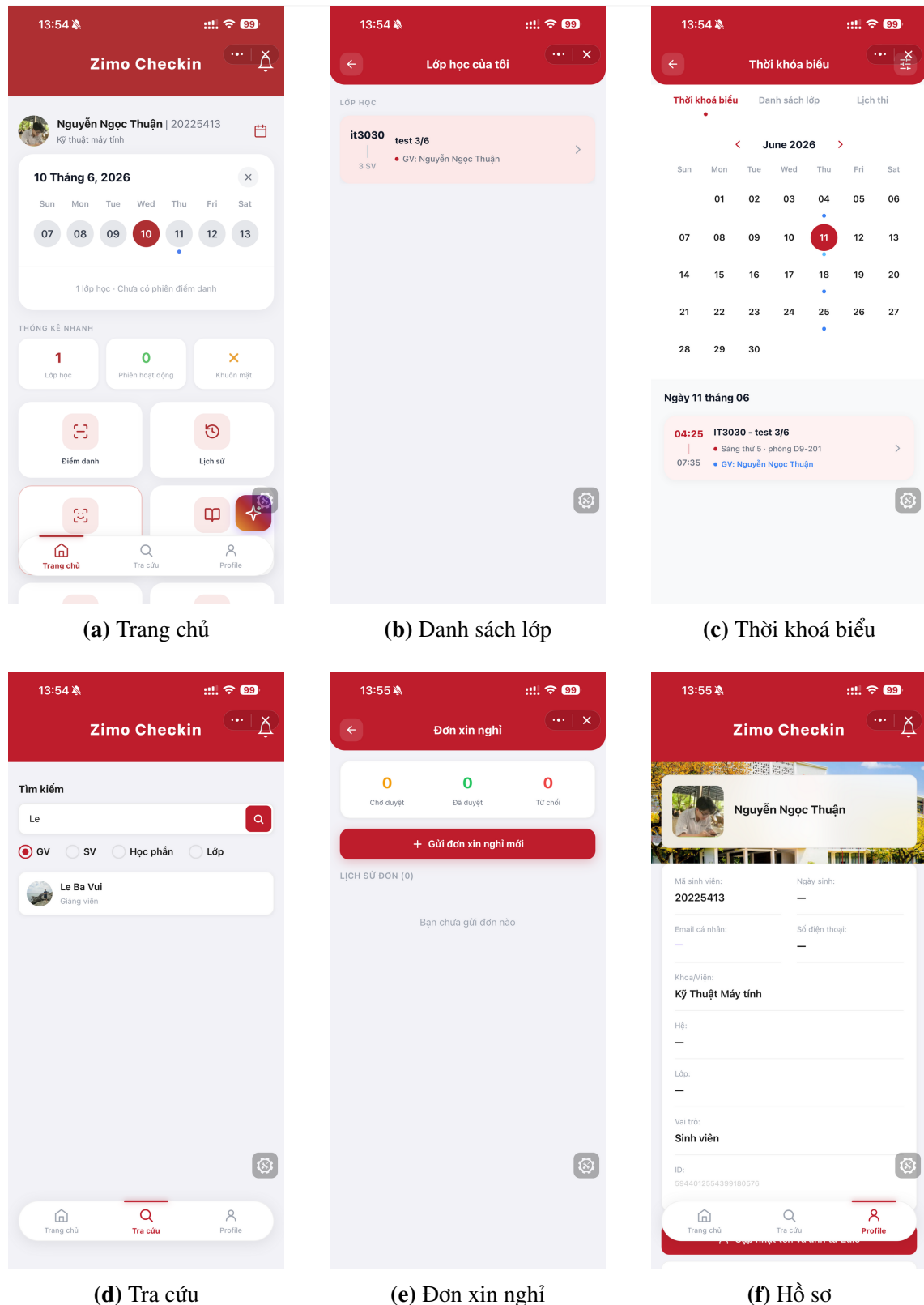
Hình 4.10: Sơ đồ phân lớp các thành phần phần mềm của Mini App

Các trang được phân theo vai trò người dùng:

- **Chung:** màn hình khởi động, giới thiệu, đăng nhập, trang chủ, hồ sơ và trợ lý hỏi đáp.
- **Sinh viên:** danh sách lớp, lịch học, đăng ký khuôn mặt, màn hình điểm danh bốn bước và lịch sử điểm danh.
- **Giảng viên:** danh sách lớp, chi tiết lớp, tạo và quản lý phiên điểm danh, giám sát theo thời gian thực, duyệt kết quả, báo cáo gian lận và thống kê.

Việc giao tiếp với nền tảng Zalo được thực hiện qua ZMP SDK, gồm xác thực người dùng, truy cập máy ảnh để quét mã QR và chụp ảnh khuôn mặt, và truy cập vị trí GPS. Một số màn hình tiêu biểu được minh hoạ trong Hình 4.11.

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG



Hình 4.11: Một số màn hình chính của Mini App

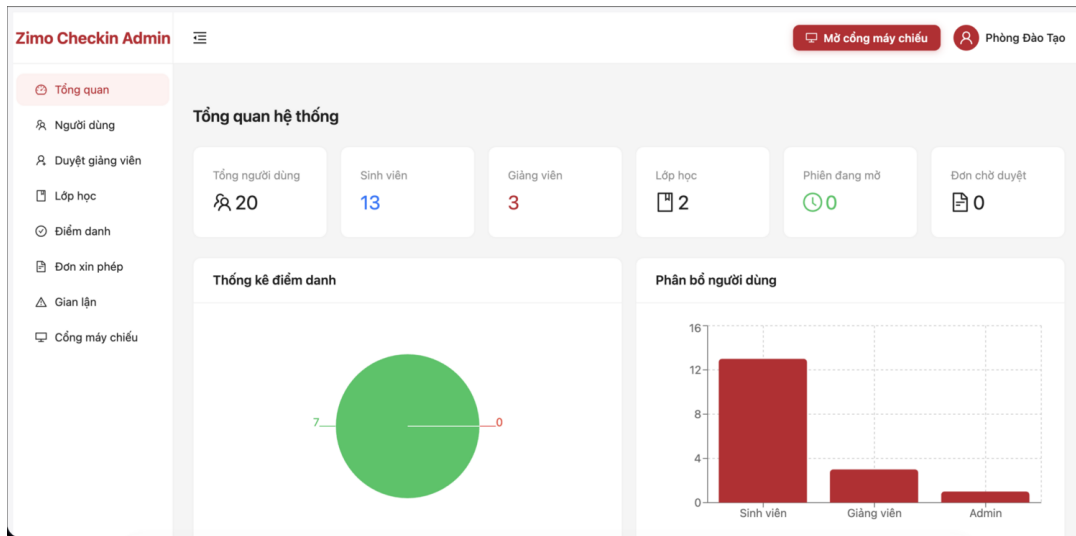
4.3.2 Triển khai trang quản trị

Trang quản trị là một ứng dụng web độc lập dành cho phòng đào tạo, được xây dựng bằng React kết hợp thư viện giao diện Ant Design, thư viện biểu đồ Recharts và thư viện `xlsx` để nhập/xuất dữ liệu Excel. Trang gồm 12 màn hình chính, trong

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

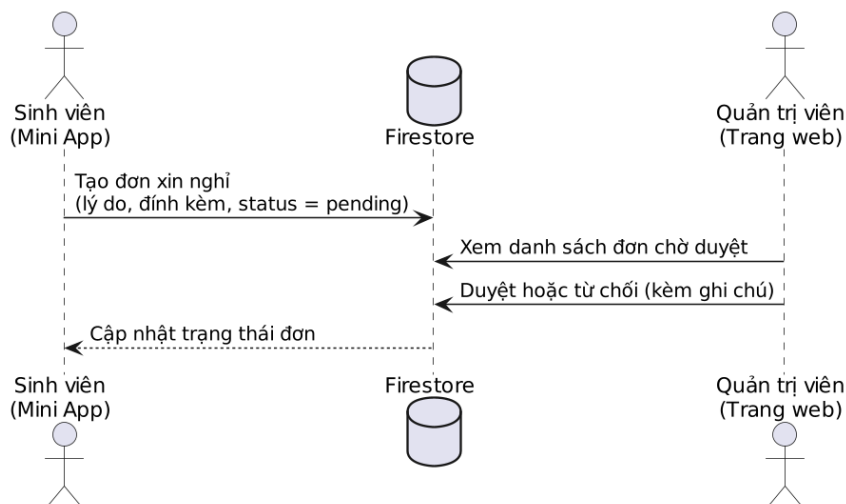
đó nổi bật là: bảng điều khiển thống kê tổng quan, quản lý người dùng, quản lý lớp học, theo dõi điểm danh, duyệt đơn xin nghỉ, báo cáo gian lận và quản lý mã mời giảng viên.

Hai tính năng đặc thù của trang quản trị là **nhập danh sách sinh viên và lớp hàng loạt từ tệp Excel** và **xuất báo cáo điểm danh ra Excel**, giúp giảm đáng kể công sức nhập liệu thủ công cho phòng đào tạo. Trang quản trị được triển khai trên Firebase Hosting. Giao diện được minh họa trong Hình 4.12.



Hình 4.12: Bảng điều khiển tổng quan của trang quản trị

Quy trình xử lý đơn xin nghỉ giữa sinh viên và quản trị viên được minh họa trong Hình 4.13.



Hình 4.13: Lược đồ tuần tự xử lý đơn xin nghỉ

4.3.3 Triển khai Cloud Functions

Toàn bộ nghiệp vụ nhạy cảm được xử lý phía máy chủ thông qua 24 hàm Cloud Functions, được phân nhóm theo chức năng như trong Bảng 4.8. Việc tập trung logic ở máy chủ bảo đảm khoá bí mật HMAC, thuật toán chống gian lận và việc gán vai trò không bị can thiệp từ phía thiết bị người dùng.

Bảng 4.8: Phân nhóm các hàm Cloud Functions

Nhóm	Các hàm
Phiên điểm danh	startSession, endSession
Điểm danh	scanTeacher, scanPeer, submitFaceResult, manualAttendance, reviewAttendance, calculateTrustPolicies
Khuôn mặt	registerFace, verifyFace
Chống gian lận	analyzeFraud, weeklyFraudAnalysis
Xác thực & phân quyền	createFirebaseToken, verifyZaloToken, resolveZaloPhoneToken, assignTeacherRole
Quản trị	adminDashboardStats, adminBulkAssignStudents, adminReviewAbsenceRequest, adminCreateAccount
Thông báo & AI	notifySessionStarted, aiChat

Một số hàm tiêu biểu được mô tả chi tiết hơn như sau. Nhóm **phiên điểm danh** gồm startSession (sinh khoá bí mật HMAC và khởi tạo phiên) và endSession (đóng phiên, chốt kết quả). Nhóm **điểm danh** là nhóm cốt lõi: scanTeacher xác minh mã QR của giảng viên, scanPeer xác minh mã ngang hàng giữa các sinh viên, submitFaceResult ghi nhận kết quả khuôn mặt, còn calculateTrustPolicies tổng hợp và tính điểm tin cậy cho toàn phiên.

Nhóm **xác thực và phân quyền** đảm nhiệm việc bắc cầu danh tính: verifyZaloToken kiểm tra token Zalo, createFirebaseToken sinh Custom Token, assignTeacherRole gán vai trò giảng viên (chỉ ở phía máy chủ). Nhóm **chống gian lận** gồm analyzeFraud chạy theo yêu cầu và weeklyFraudAnalysis chạy định kỳ. Việc tập trung toàn bộ các nghiệp vụ nhạy cảm tại tầng máy chủ là một quyết định thiết kế quan trọng nhằm bảo đảm an toàn cho hệ thống. Mã nguồn chi tiết của một số hàm cốt lõi được trích dẫn trong Phụ lục B.

4.4 Kiểm thử và đánh giá

Phần này trình bày kết quả kiểm thử cùng các đánh giá về bảo mật và hiệu năng của hệ thống.

4.4.1 Kiểm thử

Do hệ thống bao gồm nhiều thành phần tương tác trực tiếp với phần cứng thiết bị (máy ảnh, cảm biến vị trí) và với nền tảng Zalo, việc kiểm thử được thực hiện chủ yếu theo hình thức **kiểm thử thử công** theo hướng hộp đen (black-box) trên thiết bị thật. Mục tiêu là kiểm chứng tính đúng đắn của từng luồng nghiệp vụ từ góc nhìn người dùng cuối, thay vì chỉ kiểm tra từng hàm riêng lẻ. Bên cạnh đó, toàn bộ mã nguồn được kiểm tra kiểu tĩnh bằng trình biên dịch TypeScript (`tsc --noEmit`) nhằm phát hiện sớm các lỗi kiểu dữ liệu trước khi chạy.

Môi trường kiểm thử sử dụng bốn điện thoại thông minh cài sẵn Zalo: một máy đóng vai giảng viên và ba máy đóng vai sinh viên (đủ để mô phỏng bước xác minh ngang hàng, vốn chỉ cần tối thiểu một lượt), cùng kết nối Internet qua Wi-Fi hoặc mạng di động. Ngoài ra, ứng dụng còn cung cấp một chế độ giả lập dữ liệu (mock mode) cho phép kiểm thử riêng lẻ từng bước trong luồng điểm danh mà không phụ thuộc vào dữ liệu thật.

Bộ kịch bản kiểm thử gồm **72 kịch bản** (TC-01 đến TC-72) được tổ chức thành 19 nhóm chức năng, bao phủ toàn bộ các luồng chính của ứng dụng và 17 tình huống biên. Mỗi kịch bản mô tả rõ điều kiện tiên đề, các bước thực hiện, kết quả mong đợi và ô đánh dấu Đạt/Không đạt. Phân bố số lượng kịch bản theo nhóm chức năng được trình bày trong Bảng 4.9.

Bảng 4.9: Phân bố kịch bản kiểm thử theo nhóm chức năng

Nhóm chức năng	Số kịch bản
Xác thực & onboarding	6
Trang chủ (dashboard)	3
Quản lý lớp học (giảng viên)	3
Tham gia lớp học (sinh viên)	4
Phiên điểm danh (giảng viên)	5
Điểm danh bốn bước (sinh viên)	4
Theo dõi thời gian thực	3
Kết thúc phiên & điểm tin cậy	2
Xem xét & ghi đề kết quả	4
Điểm danh thử công	2
Lịch sử điểm danh (sinh viên)	2
Đăng ký khuôn mặt	2
Hồ sơ người dùng	4
Trợ lý AI	4
Báo cáo gian lận	2
Thống kê (analytics)	1
Cấu hình bước tùy chọn	3
Lịch học	1
Tình huống biên (edge case)	17
Tổng cộng	72

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

Một số kịch bản tiêu biểu, đại diện cho các cơ chế cốt lõi của hệ thống, được liệt kê trong Bảng 4.10.

Bảng 4.10: Một số kịch bản kiểm thử tiêu biểu

Mã	Mục tiêu kiểm thử	Kết quả mong đợi
TC-05	Ràng buộc định dạng MSSV	MSSV không đủ 8 số hoặc không bắt đầu bằng “20” bị từ chối
TC-18	Mã QR hiển thị và xoay 30 giây	Mã QR tự làm mới sau mỗi 30 giây
TC-23	Xác minh khuôn mặt tự động	So khớp đạt khi độ tin cậy không nhỏ hơn 0,7
TC-24	Tự quét mã QR ngang hàng	Yêu cầu tối thiểu một lượt tự quét hợp lệ
TC-30	Tính điểm tin cậy	Trả về present/review/absent đúng quy tắc
TC-56	Mã QR hết hạn	Mã quá 90 giây bị từ chối
TC-57	Tự quét mã của chính mình	Hệ thống chặn việc tự xác minh ngang hàng

Nhóm tình huống biên (17 kịch bản) tập trung vào các trường hợp dễ phát sinh lỗi hoặc bị lợi dụng, ví dụ: mã QR đã hết hạn, sinh viên tự quét mã của chính mình ở bước ngang hàng, quét trùng một bạn đã xác minh, hoặc mất kết nối mạng giữa chừng. Đây cũng chính là những điểm mà cơ chế chống gian lận và khả năng chống chịu lỗi của hệ thống được kiểm chứng.

Quá trình kiểm thử được thực hiện trên thiết bị thật, mỗi kịch bản được đánh dấu Đạt hoặc Không đạt trong tài liệu kế hoạch kiểm thử. Các luồng nghiệp vụ chính — đăng nhập và phân vai, tạo và quản lý phiên điểm danh, điểm danh bốn bước, tính điểm tin cậy, xem xét và ghi đè kết quả — đều hoạt động đúng kỳ vọng. Một số lỗi phát hiện trong quá trình kiểm thử, chủ yếu liên quan đến việc xử lý tình huống biên và độ trễ khởi động máy ảnh, đã được ghi nhận và khắc phục.

4.4.2 Đánh giá bảo mật

Vì điểm danh chống gian lận về bản chất là một bài toán bảo mật, hệ thống được rà soát một cách có hệ thống theo các nhóm chủ đề quen thuộc (tương tự phân loại của OWASP): xác thực, phân quyền, kiểm tra đầu vào, mã hoá, bảo vệ dữ liệu, an toàn của tầng máy chủ và xử lý lỗi. Mỗi lĩnh vực được đánh giá cả về những gì đã đạt được lẫn những gì cần cải thiện, kèm theo một mức điểm định tính. Kết quả tổng hợp được trình bày trong Bảng 4.11.

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

Bảng 4.11: Bảng điểm đánh giá bảo mật theo lĩnh vực

Lĩnh vực	Hiện trạng	Điểm
Xác thực	Đã có cơ chế cơ bản qua Zalo và Custom Token	7/10
Phân quyền	Firestore rules chặt chẽ, giới hạn vai trò	9/10
Kiểm tra đầu vào	Nhiều hàm kiểm tra và làm sạch dữ liệu	8/10
Mã hoá mã QR	HMAC-SHA256 mạnh, khoá bí mật được bảo vệ	9/10
Chống gian lận	Kiểm tra phía máy chủ	7/10
Bảo vệ khoá API	Đã chuyển toàn bộ về phía máy chủ	8/10
Bảo vệ dữ liệu	Rules tốt, song localStorage chưa mã hoá	7/10
Cloud Functions	Có xác thực và giới hạn tần suất	8/10
Xử lý lỗi	Có cơ chế bắt lỗi và thông báo	7/10
Mạng & ngoại tuyến	Có hàng đợi ngoại tuyến	6/10
Tổng điểm		7,6/10

Trong quá trình rà soát, sáu lỗ hổng đã được phát hiện và khắc phục, nâng điểm bảo mật tổng thể từ 6,2/10 lên 7,6/10. Các lỗ hổng cùng biện pháp khắc phục tương ứng được tóm tắt trong Bảng 4.12.

Bảng 4.12: Các lỗ hổng bảo mật đã phát hiện và khắc phục

Lỗ hổng	Mức độ	Biện pháp khắc phục
Khoá API lộ trong gói mã phía trình duyệt	Cao	Chuyển lời gọi sang Cloud Function, xoá khoá khỏi phần frontend
Khoá API thật nằm trong tệp ví dụ cấu hình	Cao	Thay bằng giá trị mẫu và thu hồi khoá cũ
Khoá bí mật HMAC lộ qua Firestore	Cao	Chuyển vào subcollection chỉ giảng viên đọc; Cloud Function kiểm tra mã
Không giới hạn vai trò khi tạo người dùng	Cao	Rule chỉ cho phép vai trò rỗng hoặc “student”
Đường dự phòng điểm danh bỏ qua kiểm tra	Trung bình	Siết chặt rule và bắt buộc đi qua Cloud Function
Giả mạo xác minh ngang hàng phía thiết bị	Trung bình	Chuyển khâu xác minh sang máy chủ (hàm scanPeer)

Nhìn chung, hệ thống có nền tảng bảo mật tốt: mã QR được ký bằng HMAC-SHA256 với khoá bí mật được cô lập, quy tắc Firestore ngăn người dùng tự nâng quyền, toàn bộ nghiệp vụ nhạy cảm được xử lý phía máy chủ, và mã nguồn không sử dụng các hàm nguy hiểm như `eval` hay `innerHTML`. Một số hạn chế vẫn còn ở mức ưu tiên trung bình và dài hạn: dữ liệu trong `localStorage` chưa được mã hoá; cơ chế giới hạn tần suất và chống phát lại (nonce) hiện lưu trong bộ nhớ tạm

CHƯƠNG 4. PHÂN TÍCH THIẾT KẾ, TRIỂN KHAI VÀ ĐÁNH GIÁ HỆ THỐNG

nên không bền vững khi mở rộng quy mô; và hệ thống chưa có nhật ký kiểm toán (audit log) hay tự đăng xuất sau thời gian dài. Đây là các định hướng để nâng mức độ bảo mật lên cao hơn.

4.4.3 Đánh giá hiệu năng

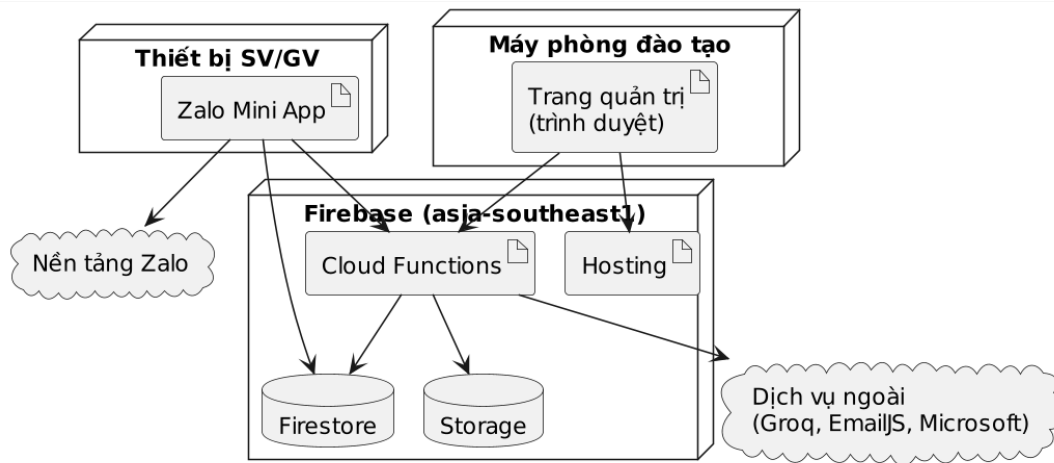
Hiệu năng phía thiết bị được tối ưu bằng cách **tải trễ** (lazy-load) các mô hình nhận diện khuôn mặt: bộ mô hình có dung lượng khoảng 6,4 MB chỉ được tải khi người dùng vào các trang cần đến, thay vì tải ngay lúc khởi động, nhờ đó thời gian mở ứng dụng được giữ ở mức thấp. Hệ thống cũng lựa chọn mô hình phát hiện khuôn mặt gọn nhẹ để có thể chạy trực tiếp trên thiết bị di động.

Tính năng giám sát điểm danh theo thời gian thực dựa trên cơ chế lắng nghe thay đổi (onSnapshot) của Firestore, cho phép cập nhật gần như tức thời mà không cần liên tục hỏi vòng máy chủ (polling), qua đó tiết kiệm băng thông và phản hồi nhanh. Ở phía máy chủ, các hàm Cloud Functions hoạt động theo mô hình serverless tự co giãn theo tải và được đặt tại khu vực `asia-southeast1` (gần người dùng tại Việt Nam) nhằm giảm độ trễ. Khi mạng chập chờn, hàng đợi ngoại tuyến và cơ chế lưu đệm cục bộ giúp người dùng vẫn thao tác được, dữ liệu sẽ được đồng bộ lại khi có kết nối.

Về hạn chế, độ trễ khởi động nguội (cold start) của Cloud Functions có thể làm chậm các yêu cầu đầu tiên sau một khoảng thời gian không hoạt động; bên cạnh đó, hiệu năng của khâu nhận diện khuôn mặt phụ thuộc vào cấu hình của từng thiết bị. Việc đo đặc hiệu năng một cách định lượng (thời gian phản hồi, thông lượng) trên nhiều cấu hình thiết bị khác nhau là một hướng phát triển tiếp theo của đề án.

4.5 Triển khai và phát hành

Hệ thống được phát hành theo nhiều kênh tương ứng với từng thành phần. Mini App được đóng gói và phát hành lên nền tảng Zalo thông qua công cụ dòng lệnh (`zmp deploy`) và phải trải qua quy trình kiểm duyệt của Zalo trước khi đến tay người dùng. Trang quản trị được triển khai trên Firebase Hosting; còn các hàm Cloud Functions, quy tắc bảo mật và chỉ mục của Firestore được triển khai qua công cụ Firebase CLI. Ở giai đoạn hiện tại, hệ thống chạy trên gói miễn phí (Spark); để đưa vào sử dụng thực tế ở quy mô lớn, cần nâng lên gói trả phí (Blaze) nhằm khai thác đầy đủ năng lực của Cloud Functions. Tô-pô triển khai vật lý của hệ thống được minh họa trong Hình 4.14.



Hình 4.14: Sơ đồ triển khai vật lý của hệ thống

Về tuân thủ chính sách nền tảng, ứng dụng tuân theo quy định của Zalo Mini App: không yêu cầu cấp quyền ngay khi mở ứng dụng mà chỉ xin quyền khi người dùng chủ động thực hiện thao tác liên quan; định danh người dùng được lấy qua `getUserID` (không cần quyền), trong khi thông tin cá nhân và số điện thoại được xin theo từng phạm vi riêng. Ứng dụng cũng cung cấp đầy đủ Điều khoản sử dụng và Chính sách quyền riêng tư cho người dùng.

Về bảo vệ dữ liệu cá nhân, dữ liệu khuôn mặt chỉ được lưu dưới dạng véc-tơ đặc trưng 128 chiều chứ không lưu ảnh gốc trên máy chủ, giúp giảm rủi ro lộ lọt dữ liệu sinh trắc học. Trong quá trình chuẩn bị phát hành rộng rãi, sản phẩm cũng được điều chỉnh theo hướng trung lập về thương hiệu — gỡ bỏ các tham chiếu định danh của một cơ sở đào tạo cụ thể khỏi giao diện và chính sách — qua đó thuận lợi hơn cho việc triển khai cho nhiều đơn vị khác nhau.

Kết chương

Chương này đã trình bày trọn vẹn quá trình hiện thực hoá hệ thống: từ thiết kế kiến trúc ba tầng, cơ sở dữ liệu Firestore, luồng xác thực — phân quyền và các thuật toán cốt lõi (mã QR HMAC xoay, điểm danh bốn bước, chống gian lận nhiều lớp, cổng máy chiếu), đến việc triển khai thành ba sản phẩm thực tế (Mini App, trang quản trị và các hàm máy chủ), và cuối cùng là kết quả kiểm thử cùng các đánh giá về bảo mật (đạt 7,6/10), hiệu năng và quy trình phát hành. Kết quả cho thấy hệ thống đã đáp ứng được các yêu cầu chức năng và phi chức năng đã đề ra, đồng thời cũng bộc lộ một số hạn chế làm tiền đề cho các cải tiến tiếp theo. Chương sau sẽ đi sâu vào những giải pháp và đóng góp nổi bật nhất của đề án.

CHƯƠNG 5. CÁC GIẢI PHÁP VÀ ĐÓNG GÓP NỔI BẬT

Chương 4 đã trình bày chi tiết cách hệ thống được thiết kế và hiện thực hoá. Chương này nhìn lại những giải pháp kỹ thuật mang tính **đóng góp nổi bật** nhất — đã được liệt kê tóm tắt ở mục 1.3 — và phân tích sâu hơn về lý do chúng tạo nên sự khác biệt của hệ thống so với các cách làm thông thường, kèm theo những ưu điểm và giới hạn còn tồn tại. Để tránh trùng lặp, phần mô tả cơ chế hoạt động chi tiết được tham chiếu tới các mục tương ứng trong Chương 4.

5.1 Cơ chế mã QR HMAC xoay theo thời gian

Phần lớn các hệ thống điểm danh bằng mã QR hiện nay sử dụng **mã QR tĩnh**: mỗi buổi học (hoặc mỗi lớp) gắn với một mã cố định. Điểm yếu cố hữu của cách làm này là mã có thể bị chụp màn hình và gửi cho người vắng mặt, khiến việc “điểm danh hộ” từ xa trở nên dễ dàng — đây chính là hình thức gian lận phổ biến nhất mà Chương 2 đã chỉ ra.

Đóng góp của đề án là thay thế mã tĩnh bằng **mã QR động được ký bằng HMAC-SHA256 và làm mới sau mỗi 30 giây** (cơ chế và thuật toán sinh mã đã được trình bày ở mục 4.2.3 và Thuật toán 1). Giá trị cốt lõi nằm ở ba tính chất kết hợp: (i) mã chỉ có hiệu lực trong cửa sổ ngắn (90 giây) nên ảnh chụp nhanh chóng hết hạn; (ii) chữ ký HMAC khiến không thể tự tạo ra một mã hợp lệ nếu không có khoá bí mật — vốn được cô lập ở phía máy chủ; và (iii) mốc thời gian gắn trong mã ngăn việc phát lại (replay).

Một điểm tinh tế nhưng quan trọng là cơ chế **đồng bộ đồng hồ giữa nhiều nguồn hiển thị**: mã QR trên điện thoại giảng viên và mã trên màn hình máy chiếu (mục 4.2.7) cùng được sinh theo một mốc thời gian thống nhất, nhờ đó luôn khớp nhau ở mỗi chu kỳ làm mới. Cửa sổ dung sai 90 giây (gấp ba lần chu kỳ) được lựa chọn để dung hoà sai lệch đồng hồ giữa các thiết bị mà vẫn giữ thời gian sống của mã đủ ngắn. Nhờ cách tiếp cận này, hệ thống vô hiệu hoá hình thức gian lận phổ biến nhất mà không đòi hỏi bất kỳ phần cứng chuyên dụng nào, chỉ dùng chính chiếc điện thoại sẵn có của người dùng.

5.2 Cổng máy chiếu và cơ chế pairing one-shot

Khi áp dụng mã QR động vào lớp học đông, một vấn đề thực tiễn nảy sinh: mã hiển thị trên màn hình điện thoại của giảng viên quá nhỏ để sinh viên ở cuối phòng có thể quét, trong khi việc chuyển tay điện thoại vừa bất tiện vừa mất an toàn. Đây là rào cản thường bị bỏ qua trong các nghiên cứu nhưng lại quyết định khả năng sử dụng thực tế của hệ thống.

Đóng góp của đề án là tính năng **Cổng máy chiếu** (mục 4.2.7): một trang web mở trên máy chiếu của lớp sẽ hiển thị mã QR động cỡ lớn, được liên kết với phiên điểm danh của giảng viên thông qua một **mã ghép nối dùng một lần** (one-shot pairing token) dài 128 bit, có thời hạn 60 giây.

Điểm mới về mặt an toàn nằm ở **quy tắc chuyển trạng thái một chiều**: mã ghép nối chỉ đi từ trạng thái pending sang paired đúng một lần, không thể quay lại cũng không thể bị ghép nối lần thứ hai. Thiết kế này ngăn chặn nguy cơ một bên thứ ba chiếm quyền hiển thị (hijack) màn hình máy chiếu để phát mã giả. Nhờ đó, tính năng vừa giải quyết bài toán khả dụng cho lớp đông, vừa giữ nguyên các bảo đảm an toàn của cơ chế mã QR động — một sự kết hợp giữa trải nghiệm người dùng và bảo mật mà các ứng dụng điểm danh thông thường ít khi cung cấp.

5.3 Hệ thống chống gian lận nhiều lớp

Hầu hết các hệ thống điểm danh hiện có chỉ dựa trên **một yếu tố xác minh duy nhất** (một lần quét mã, hoặc một lần nhận diện khuôn mặt). Hệ quả là chỉ cần vượt qua yếu tố đó là gian lận thành công — một điểm thất bại đơn lẻ (single point of failure).

Đóng góp của đề án là một quy trình điểm danh **đa yếu tố bốn bước** (mã QR, khuôn mặt, xác minh ngang hàng và định vị) được tổng hợp bằng điểm tin cậy (mục 4.2.5), thiết kế theo nguyên lý **phòng thủ theo chiều sâu** (defense in depth): mỗi lớp chống lại một hình thức gian lận khác nhau, và để qua mặt hệ thống, người gian lận phải vượt qua đồng thời nhiều lớp. Sự tương ứng giữa từng lớp xác minh và hình thức gian lận bị ngăn chặn được tóm tắt trong Bảng 5.1.

Bảng 5.1: Các lớp xác minh và hình thức gian lận bị ngăn chặn

Lớp xác minh	Hình thức gian lận bị ngăn chặn
Mã QR động (HMAC)	Chụp và chia sẻ lại mã để điểm danh hộ
Xác minh khuôn mặt	Nhờ người khác điểm danh thay
Xác minh ngang hàng	Điểm danh từ xa khi không thực sự có mặt
Định vị GPS	Điểm danh khi đang ở ngoài khu vực lớp học
Phân tích hành vi phía máy chủ	Thông đồng có hệ thống (cùng nhóm, xác minh quá nhanh...)

Trong các lớp trên, **xác minh ngang hàng** (peer-to-peer) là đóng góp giàu tính mới mẻ nhất. Thay vì chỉ tin vào một bằng chứng do chính sinh viên cung cấp, hệ thống yêu cầu sinh viên tự quét mã QR của ít nhất một bạn xung quanh (chỉ lượt tự quét mới được tính); việc xác minh chéo này tạo ra một **bằng chứng về sự hiện diện vật lý** mà một yếu tố đơn lẻ (mã hay khuôn mặt) khó tạo ra được — rất khó để tự quét được mã của một bạn đang có mặt trong phòng nếu bản thân không thực sự

có mặt. Bổ trợ cho lớp phòng ngừa này, một hàm phân tích chạy phía máy chủ rà soát các mẫu hành vi đáng ngờ (Bảng 4.7) như luôn xác minh với cùng một nhóm hay tốc độ xác minh bất thường, qua đó bổ sung thêm một lớp **phát hiện** bên cạnh các lớp **ngăn chặn**.

Cần thẳng thắn nhìn nhận giới hạn: xác minh ngang hàng vẫn có thể bị một nhóm sinh viên thông đồng cùng có mặt để xác minh không cho nhau. Tuy nhiên, chính lớp phân tích hành vi được thiết kế để phát hiện kiểu thông đồng lặp lại này, và việc kết hợp nhiều lớp khiến chi phí gian lận tăng cao hơn đáng kể so với hệ thống chỉ dùng một yếu tố.

5.4 Kiến trúc ba vai trò và phân quyền

Một thách thức của đề tài là phải thực thi phân quyền chặt chẽ trên một nền tảng bị ràng buộc: Zalo Mini App không có máy chủ xác thực truyền thống, còn hệ thống vận hành phần lớn trên gói dịch vụ miễn phí của Firebase. Trong bối cảnh đó, việc bảo đảm mỗi vai trò chỉ làm đúng phần việc của mình là không hiển nhiên.

Đóng góp của đồ án là một **kiến trúc ba vai trò** (sinh viên, giảng viên, quản trị) với phân quyền được thực thi ngay tại tầng cơ sở dữ liệu bằng quy tắc bảo mật của Firestore, kết hợp cơ chế cấp token tùy biến (mục 4.2.2, Bảng 4.6). Nguyên tắc thiết kế cốt lõi là **ngăn tự nâng quyền** (privilege escalation): tài khoản tạo từ phía thiết bị chỉ được mang vai trò `student`, còn vai trò giảng viên hay quản trị chỉ có thể được gán bởi hàm phía máy chủ. Đồng thời, mọi nghiệp vụ nhạy cảm — ký mã QR, tính điểm tin cậy, phát hiện gian lận — đều được tập trung xử lý ở máy chủ để không thể bị can thiệp từ thiết bị người dùng.

Điểm đáng chú ý là kiến trúc này đạt được mô hình **đặc quyền tối thiểu** (least privilege) và chống leo thang quyền mà **không cần một máy chủ ứng dụng riêng**, qua đó phù hợp với ràng buộc và chi phí của nền tảng. Giới hạn hiện tại — một số quy tắc còn dựa trên cấu trúc dữ liệu thay vì danh tính đầy đủ do hạn chế của gói miễn phí — đã được nhận diện và có thể khắc phục khi nâng cấp gói dịch vụ, như đã đề cập ở mục 4.4.2.

5.5 Tuân thủ chính sách nền tảng Zalo

Nhiều sản phẩm thử nghiệm trong môi trường học thuật thường bỏ qua các yêu cầu về chính sách nền tảng và quyền riêng tư, dẫn tới việc không thể thực sự phát hành tới người dùng. Đồ án này xác định **khả năng triển khai thực tế** là một mục tiêu, nên việc tuân thủ chính sách trở thành một đóng góp có ý nghĩa thực tiễn.

Cụ thể, ứng dụng được xây dựng để tuân thủ chính sách của Zalo Mini App: không yêu cầu cấp quyền tại thời điểm mở ứng dụng mà chỉ xin quyền khi người

dùng chủ động thao tác, và xin theo từng phạm vi riêng biệt (thông tin cá nhân, số điện thoại). Hệ thống cung cấp đầy đủ Điều khoản sử dụng và Chính sách quyền riêng tư, đồng thời xử lý **dữ liệu sinh trắc học một cách có trách nhiệm**: khuôn mặt chỉ được lưu dưới dạng véc-tơ đặc trưng 128 chiều chứ không lưu ảnh gốc, trên cơ sở có sự đồng thuận của người dùng.

Hướng tới khả năng áp dụng cho nhiều cơ sở đào tạo khác nhau, sản phẩm còn được điều chỉnh theo hướng trung lập về thương hiệu. Những yếu tố này tuy không nằm ở phần “lõi thuật toán” nhưng lại là điều kiện cần để một hệ thống điểm danh có thể đi từ nguyên mẫu tới một sản phẩm dùng được trong thực tế.

Kết chương

Chương này đã phân tích năm đóng góp nổi bật của đồ án: cơ chế mã QR động HMAC có đồng bộ đa thiết bị, tính năng Cổng máy chiếu với ghép nối một chiều an toàn, hệ thống chống gian lận nhiều lớp với điểm nhấn là xác minh ngang hàng, kiến trúc phân quyền chặt chẽ trên nền tảng bị ràng buộc, và việc tuân thủ chính sách nền tảng hướng tới triển khai thực tế. Xuyên suốt các đóng góp này là một tư tưởng nhất quán: nâng cao tính trung thực của điểm danh bằng cách kết hợp nhiều lớp bảo vệ chi phí thấp, trong khi vẫn giữ trải nghiệm đơn giản cho người dùng và khả năng triển khai thực tế. Phần kết luận sau đây sẽ nhìn lại toàn bộ kết quả và bàn về các định hướng mở rộng tiếp theo.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1 Kết luận

Đồ án đã hoàn thành mục tiêu xây dựng một hệ thống điểm danh thông minh, chống gian lận trên nền tảng Zalo Mini App, áp dụng được cho môi trường đào tạo đại học. Đối chiếu với các mục tiêu cụ thể đặt ra ở mục 1.2, kết quả đạt được như sau:

- **Mã QR động chống chia sẻ.** Hệ thống đã hiện thực mã QR ký bằng HMAC-SHA256, xoay theo chu kỳ 30 giây và đồng bộ giữa điện thoại giảng viên với màn hình máy chiếu, qua đó vô hiệu hoá việc chụp và chia sẻ lại mã.
- **Xác minh khuôn mặt phía thiết bị.** Việc nhận diện khuôn mặt được thực hiện ngay trên thiết bị người dùng, chỉ lưu véc-tơ đặc trưng 128 chiều thay vì ảnh gốc.
- **Xác minh ngang hàng.** Cơ chế mỗi sinh viên tự quét mã của bạn (tối thiểu một lượt, chỉ lượt tự quét mới được tính) đã tạo ra bằng chứng về sự hiện diện vật lý, chống điểm danh từ xa.
- **Trang quản trị web.** Đã xây dựng trang quản trị cho giảng viên và phòng đào tạo với các chức năng quản lý lớp, giám sát phiên theo thời gian thực và xuất báo cáo Excel.
- **Phát hiện gian lận nhiều lớp.** Hệ thống tổng hợp bốn yếu tố xác minh thành điểm tin cậy và bổ sung hàm phân tích phía máy chủ để phát hiện, lập báo cáo tự động các mẫu hành vi đáng ngờ.

Về sản phẩm, đồ án đã tạo ra ba thành phần hoạt động được: một Mini App cho sinh viên và giảng viên, một trang quản trị web, và một tập các hàm xử lý phía máy chủ trên nền tảng Firebase (chi tiết ở Chương 4). Hệ thống đã được kiểm thử theo bộ 72 kịch bản và đạt mức điểm tự đánh giá bảo mật 7,6/10. Những đóng góp nổi bật — đặc biệt là cơ chế xác minh ngang hàng và mã QR động có đồng bộ đa thiết bị (Chương 5) — cho thấy có thể nâng cao đáng kể tính trung thực của điểm danh bằng các lớp bảo vệ chi phí thấp, chỉ dựa trên thiết bị sẵn có của người dùng mà không cần phần cứng chuyên dụng.

6.2 Hạn chế

Bên cạnh các kết quả đạt được, đồ án vẫn còn một số hạn chế cần được nhìn nhận một cách thẳng thắn:

- **Phạm vi triển khai.** Hệ thống mới được thử nghiệm ở mức thử nghiệm (pilot)

trong khuôn khổ một đề án, chưa triển khai ở quy mô toàn trường; kết quả kiểm thử do đó còn mang tính định tính, chưa có số liệu trên tập người dùng lớn.

- **Một số nội dung ngoài phạm vi.** Hệ thống chưa tích hợp với hệ thống quản lý học tập (LMS) của nhà trường, chưa hỗ trợ thẻ sinh viên RFID/NFC, và mới dừng ở mức phát hiện sự sống (liveness) cơ bản nên vẫn còn rủi ro bị qua mặt bằng ảnh hoặc video.
- **Bảo mật và vận hành.** Một số dữ liệu phía thiết bị (`localStorage`) chưa được mã hoá; cơ chế giới hạn tần suất và chống phát lại còn lưu trong bộ nhớ tạm nên không bền vững khi mở rộng quy mô; hệ thống cũng chưa có nhật ký kiểm toán và hiện vẫn vận hành trên gói dịch vụ miễn phí (xem mục 4.4.2).
- **Gian lận còn lại.** Xác minh ngang hàng vẫn có thể bị một nhóm sinh viên thông đồng cùng có mặt để xác minh không cho nhau; lớp phân tích hành vi chỉ giảm thiểu chứ chưa loại bỏ hoàn toàn rủi ro này.
- **Hiệu năng.** Đề án chưa thực hiện đo đặc hiệu năng định lượng (thời gian phản hồi, thông lượng) trên nhiều cấu hình thiết bị khác nhau.

6.3 Hướng phát triển

Từ những hạn chế nêu trên, đề án đề xuất các hướng phát triển tiếp theo, sắp xếp theo mức độ ưu tiên:

- **Củng cố bảo mật và vận hành.** Mã hoá dữ liệu trên thiết bị; chuyển cơ chế giới hạn tần suất và chống phát lại sang lưu trữ bền vững; bổ sung nhật ký kiểm toán, tự đăng xuất sau thời gian dài và nâng cấp lên gói dịch vụ trả phí để khai thác đầy đủ năng lực máy chủ.
- **Nâng cao chống gian lận.** Áp dụng học máy để phát hiện gian lận dựa trên dữ liệu thay vì chỉ dựa trên luật; tăng cường phát hiện sự sống (chống giả mạo bằng ảnh, video) và nhận diện thiết bị bất thường.
- **Tích hợp hệ thống nhà trường.** Kết nối với hệ thống quản lý học tập (LMS), hỗ trợ thẻ sinh viên RFID/NFC và đăng nhập một lần (SSO) với tài khoản của trường.
- **Bảo vệ dữ liệu cá nhân.** Hướng tới mã hoá đầu cuối cho dữ liệu sinh trắc học, giảm thiểu lưu trữ thông tin định danh không cần thiết, và mời kiểm thử xâm nhập (penetration testing) độc lập.
- **Mở rộng sản phẩm.** Nhờ đã được điều chỉnh theo hướng trung lập về thương hiệu, hệ thống có thể được triển khai cho nhiều cơ sở đào tạo khác nhau, kèm theo các tính năng thống kê và thông báo phong phú hơn.

Tóm lại, đồ án đã xây dựng thành công một hệ thống điểm danh chống gian lận hoàn chỉnh và khả thi về mặt triển khai, đồng thời chỉ ra một lộ trình rõ ràng để tiếp tục hoàn thiện hệ thống thành một sản phẩm sẵn sàng cho môi trường thực tế.

TÀI LIỆU THAM KHẢO

- [1] Zalo, *Zalo reaches 78.3 million monthly active users*, VietnamNet, [Online]. Available: <https://vietnamnet.vn/en/zalo-s-number-of-users-hits-78-3-million-putting-telcos-at-pipeline-trap-2436470.html>. Truy cập ngày 08/06/2026, 2025.
- [2] Zalo, *Zalo mini app documentation*, <https://mini.zalo.me>, Truy cập ngày 01/06/2026, 2024.
- [3] O. T. Arulogun, A. Olatunbosun, O. A. Fakolujo, and O. M. Olaniyi, “RFID-based students attendance management system,” *International Journal of Scientific & Engineering Research*, vol. 4, no. 2, pp. 1–9, 2013.
- [4] NFC Forum, *NFC forum technical specifications*, NFC Forum, [Online]. Available: <https://nfc-forum.org>, 2020.
- [5] R. Apoorv and P. Mathur, “Smart attendance management using Bluetooth low energy and Android,” in *2016 IEEE Region 10 Conference (TENCON)*, 2016.
- [6] Apple Inc., *Getting started with iBeacon*, Apple Inc. [Online]. Available: <https://developer.apple.com/ibeacon/>, 2014.
- [7] F. Schroff, D. Kalenichenko, and J. Philbin, “FaceNet: A unified embedding for face recognition and clustering,” *Proceedings of the IEEE Conference on Computer Vision and Pattern Recognition (CVPR)*, pp. 815–823, 2015.
- [8] Zalo, *Zalo mini app — developer documentation (start, cli, deploy)*, <https://mini.zalo.me/docs/>, Truy cập ngày 25/06/2026, 2024.
- [9] Meta Open Source, *React: The library for web and native user interfaces*, Meta, [Online]. Available: <https://react.dev>, 2024.
- [10] Microsoft, *TypeScript: JavaScript with syntax for types*, Microsoft, [Online]. Available: <https://www.typescriptlang.org>, 2024.
- [11] Google, *Cloud Firestore documentation*, Google Firebase, [Online]. Available: <https://firebase.google.com/docs/firestore>, 2024.
- [12] H. Krawczyk, M. Bellare, and R. Canetti, *HMAC: Keyed-hashing for message authentication*, RFC 2104, IETF, 1997.
- [13] National Institute of Standards and Technology, *Secure hash standard (SHS)*, FIPS PUB 180-4, U.S. Department of Commerce, 2015.
- [14] M. Bellare, R. Canetti, and H. Krawczyk, “Keying hash functions for message authentication,” in *Advances in Cryptology — CRYPTO ’96*, ser. Lecture Notes in Computer Science, vol. 1109, 1996, pp. 1–15.

- [15] Y. LeCun, L. Bottou, Y. Bengio, and P. Haffner, “Gradient-based learning applied to document recognition,” *Proceedings of the IEEE*, vol. 86, no. 11, pp. 2278–2324, 1998.
- [16] K. He, X. Zhang, S. Ren, and J. Sun, “Deep residual learning for image recognition,” in *Proceedings of the IEEE Conference on Computer Vision and Pattern Recognition (CVPR)*, 2016, pp. 770–778.
- [17] Y. Taigman, M. Yang, M. Ranzato, and L. Wolf, “DeepFace: Closing the gap to human-level performance in face verification,” in *Proceedings of the IEEE Conference on Computer Vision and Pattern Recognition (CVPR)*, 2014, pp. 1701–1708.
- [18] V. Mühler, *Face-api.js: JavaScript api for face detection and recognition in the browser*, GitHub, [Online]. Available: <https://github.com/justadudewhohacks/face-api.js>, 2020.
- [19] ISO/IEC, *ISO/IEC 18004:2015 – information technology – automatic identification and data capture techniques – QR code bar code symbology specification*, International Organization for Standardization, 2015.
- [20] D. M’Raihi, S. Machani, M. Pei, and J. Rydell, *TOTP: Time-based one-time password algorithm*, RFC 6238, IETF, 2011.

PHỤ LỤC

A. HƯỚNG DẪN CÀI ĐẶT VÀ TRIỂN KHAI

Phụ lục này hướng dẫn cài đặt, cấu hình và triển khai hệ thống, giúp người đọc có thể tái dựng lại môi trường chạy của đồ án.

A.1 Yêu cầu môi trường

Để cài đặt và chạy hệ thống, cần chuẩn bị các thành phần trong Bảng A.1.

Bảng A.1: Yêu cầu môi trường cài đặt

Thành phần	Vai trò
Node.js (bản LTS) và npm	Môi trường chạy và quản lý gói cho Mini App, trang quản trị và Cloud Functions
Zalo Mini App CLI (zmp-cli)	Chạy thử và triển khai Mini App lên nền tảng Zalo
Firebase CLI	Triển khai Cloud Functions, quy tắc Firestore và trang quản trị
Tài khoản Zalo Developer	Đăng ký và quản lý Mini App
Dự án Firebase	Cung cấp Firestore, Storage và Cloud Functions

A.2 Cấu trúc mã nguồn

Mã nguồn được tổ chức thành ba phần chính cùng các tệp cấu hình, như Danh sách mã nguồn A.1.

```
1 .
2 |- src/                # Zalo Mini App (React + TypeScript + Jotai)
3 |- admin/              # Trang quan tri (React + Ant Design)
4 |- functions/          # Cloud Functions (Node.js)
5 |- app-config.json     # Cau hinh Mini App
6 |- firestore.rules     # Quy tac bao mat Firestore
7 |- firebase.json       # Cau hinh Firebase CLI
```

Danh sách mã nguồn A.1: Cấu trúc thư mục mã nguồn

A.3 Cấu hình biến môi trường

Các khoá bí mật và cấu hình được đặt trong các tệp môi trường và **không** đưa vào mã nguồn công khai. Phần chạy phía trình duyệt sử dụng tiền tố `VITE_`, còn các khoá nhạy cảm được đặt trong `functions/.env` ở phía máy chủ. Danh sách mã nguồn A.2 minh hoạ cấu trúc tệp môi trường (các giá trị chỉ là ví dụ mẫu).

```
1 # .env (Mini App - phia trinh duyet)
2 VITE_FIREBASE_API_KEY=your_api_key
3 VITE_FIREBASE_PROJECT_ID=your_project_id
4 VITE_BYPASS_MSSV=20225413
5
```

```
6 # functions/.env (phía máy chủ)
7 GROQ_API_KEY=your_groq_key
8 EMAILJS_SERVICE_ID=your_service_id
```

Danh sách mã nguồn A.2: Cấu trúc tệp môi trường (giá trị mẫu)

A.4 Chạy ở môi trường phát triển

Danh sách mã nguồn A.3 trình bày các lệnh chạy thử trên máy cá nhân. Lưu ý Mini App được chạy bằng `zmp start` (không dùng `vite` trực tiếp do cơ chế đóng gói riêng của nền tảng).

```
1 # Cài đặt phụ thuộc
2 npm install
3
4 # Chạy Mini App
5 zmp start
6
7 # Chạy trang quản trị
8 cd admin && npm install && npm run dev
9
10 # Kiểm tra kiểu TypeScript (không xuất bản dịch)
11 npx tsc --noEmit
```

Danh sách mã nguồn A.3: Lệnh chạy môi trường phát triển

A.5 Triển khai

Sau khi kiểm thử, hệ thống được triển khai theo Danh sách mã nguồn A.4. Mini App sau khi `zmp deploy` sẽ trải qua quy trình kiểm duyệt của Zalo trước khi đến tay người dùng; trang quản trị được phục vụ trên Firebase Hosting; còn Cloud Functions chạy tại khu vực `asia-southeast1`.

```
1 # Triển khai Mini App lên nền tảng Zalo
2 zmp deploy
3
4 # Triển khai Cloud Functions, rules, indexes và trang quản trị
5 firebase deploy --only functions,firestore:rules,firestore:
  indexes,hosting
```

Danh sách mã nguồn A.4: Lệnh triển khai

A.6 Khởi tạo và phân quyền

Tài khoản đăng nhập lần đầu mặc định mang vai trò sinh viên. Việc nâng quyền lên giảng viên hoặc quản trị viên chỉ được thực hiện ở phía máy chủ (thông qua hàm Cloud Function tương ứng hoặc mã mời giảng viên), nhằm ngăn việc tự nâng

quyền từ phía thiết bị. Sau khi được nâng quyền, người dùng có thể truy cập các chức năng tương ứng với vai trò như đã đặc tả ở mục 2.3.

B. TRÍCH DẪN MÃ NGUỒN

Phụ lục này trích dẫn một số đoạn mã nguồn cốt lõi của hệ thống nhằm minh hoạ cách hiện thực các cơ chế đã trình bày ở các chương trước. Mã được rút gọn (lược bỏ phần khai báo kiểu và chú thích) để tập trung vào phần logic chính.

B.1 Ký và tạo nội dung mã QR

Đoạn mã trong Danh sách mã nguồn B.1 (tệp `src/Utils/crypto.ts`) thực hiện việc ký nội dung mã QR bằng HMAC-SHA256 và tạo chuỗi JSON cuối cùng để mã hoá thành mã QR.

```
1 import CryptoJS from "crypto-js";
2
3 export function signPayload(data, secret) {
4   const message =
5     `${data.type}:${data.sessionId}:${data.userId}:${data.
6       timestamp}:${data.nonce}`;
7   return CryptoJS.HmacSHA256(message, secret).toString();
8 }
9
10 export function createQRContent(type, sessionId, userId, secret)
11   {
12     const timestamp = Date.now();
13     const nonce = CryptoJS.lib.WordArray.random(16).toString();
14     const signature =
15       signPayload({ type, sessionId, userId, timestamp, nonce },
16         secret);
17     return JSON.stringify({ type, sessionId, userId, timestamp,
18       nonce, signature });
19 }
```

Danh sách mã nguồn B.1: `crypto.ts` — ký và tạo nội dung mã QR

B.2 Sinh mã QR xoay theo thời gian

Danh sách mã nguồn B.2 (tệp `useQRGenerator.ts`) sinh lại mã QR sau mỗi 30 giây dựa trên một mốc đồng hồ chung (anchor), nhờ đó mã trên Mini App và trên máy chiếu luôn đồng bộ.

```
1 export function useQRGenerator(options) {
2   const [qrDataURL, setQrDataURL] = useState("");
3   const lastPeriodRef = useRef(-1);
4   const refreshInterval = options?.refreshIntervalMs || 30000;
5
6   useEffect(() => {
```

```

7   if (!options) return;
8   const tick = async () => {
9     const { type, sessionId, userId, secret, anchor } = options
10    ;
11    // clock anchor keeps Mini App and projector in sync
12    const useAnchor = anchor || Date.now();
13    const elapsed = Math.max(0, Date.now() - useAnchor);
14    const periodIndex = Math.floor(elapsed / refreshInterval);
15    // regenerate QR only when entering a new 30s period
16    if (periodIndex !== lastPeriodRef.current) {
17      lastPeriodRef.current = periodIndex;
18      const content = type === "teacher"
19        ? createTeacherQR(sessionId, userId, secret)
20        : createPeerQR(sessionId, userId, secret);
21      setQrDataURL(await generateQRDataURL(content));
22    }
23  };
24  tick();
25  const id = setInterval(tick, 500);
26  return () => clearInterval(id);
27 }, [options?.sessionId, options?.secret, refreshInterval]);
28
29 return { qrDataURL };

```

Danh sách mã nguồn B.2: useQRGenerator — mã QR xoay 30 giây có đồng bộ

B.3 Bảo mật phía máy chủ: chống phát lại và giới hạn tần suất

Danh sách mã nguồn B.3 (tệp `attendance.service.ts` phía máy chủ) cho thấy hàm Cloud Function `scanTeacher` kiểm tra giới hạn tần suất, theo dõi nonce để chống phát lại và xác minh chữ ký HMAC ở phía máy chủ.

```

1 // In-memory nonce tracking to prevent QR replay (TTL 120s > QR
   expiry 90s)
2 const usedNonces = new Map();
3 const NONCE_TTL_MS = 120_000;
4
5 function checkAndRecordNonce(nonce) {
6   const now = Date.now();
7   for (const [key, expiry] of usedNonces) {
8     if (now > expiry) usedNonces.delete(key);
9   }
10  if (usedNonces.has(nonce)) return false;
11  usedNonces.set(nonce, now + NONCE_TTL_MS);
12  return true;

```

```

13 }
14
15 export const scanTeacher = onCall(requireAuth(
16   async (data, ctx, userId) => {
17     if (!checkRateLimit(userId, 10, 60_000)) {
18       throw new HttpsError("resource-exhausted", "Too many requests
19         ");
20     }
21     const { qrPayload, sessionId } = data;
22     // load session secret, then verify HMAC + timestamp + nonce
23     if (!verifyHMAC(qrPayload, secret)) { /* reject: bad signature
24       */ }
25     if (!checkAndRecordNonce(qrPayload.nonce)) { /* reject: replay
26       */ }
27   })
28 );

```

Danh sách mã nguồn B.3: Cloud Function — chống phát lại và giới hạn tần suất

B.4 Tính điểm tin cậy

Danh sách mã nguồn B.4 (tệp `src/types/index.ts`) là hàm tính điểm tin cậy, hiện thực trực tiếp quy tắc đã trình bày ở Thuật toán 2.

```

1 export function computeTrustPolicy(peerCount, faceVerification,
2   config) {
3   const faceReq = config?.faceRequired !== false;
4   const peerReq = config?.peerRequired !== false;
5
6   const faceOk = faceVerification?.matched === true
7     && (faceVerification.confidence || 0) >= 0.7;
8   const faceSkipped = faceVerification?.skipped === true;
9   const faceAttempted = !!faceVerification && !faceSkipped;
10
11   const facePass = !faceReq || faceOk || faceSkipped || !
12     faceAttempted;
13   const peerPass = !peerReq || peerCount >= 1;
14
15   if (facePass && peerPass) return "present";
16   if (facePass || peerPass) return "review";
17   return "absent";
18 }

```

Danh sách mã nguồn B.4: `computeTrustPolicy` — tính điểm tin cậy

B.5 Quy tắc bảo mật Firestore

Danh sách mã nguồn B.5 (tệp `firestore.rules`) minh họa các hàm trợ giúp ngăn người dùng tự nâng quyền và quy tắc áp dụng cho collection `users`.

```
1 function notChangingRole() {
2   return !('role' in request.resource.data) ||
3     !('role' in resource.data) ||
4     request.resource.data.role == resource.data.role;
5 }
6
7 function newDocSafeRole() {
8   // new user: only role "student" is accepted
9   return !('role' in request.resource.data) ||
10     request.resource.data.role == 'student';
11 }
12
13 match /users/{userId} {
14   allow read:    if true;
15   allow create:  if newDocSafeRole();    // no self-elevation
16   allow update:  if notChangingRole();    // cannot change own role
17   allow delete:  if false;
18 }
```

Danh sách mã nguồn B.5: `firestore.rules` — chống tự nâng quyền